

CveToad Vulnerability Management Source Inventory

A consolidated super-set vulnerability-management source inventory for assessing impact, severity, exploitability, exposure, affectedness, prioritization, & remediation of vulnerabilities in technical systems.

License

Copyright © 2025 Keerthana Purushotham <keep.consult@proton.me>.
Licensed under the GNU AGPL v3. See LICENSE for details.

[see license](#)

Note:

- Some vendor/security pages change URLs over time, so treat this as a high-coverage baseline rather than a mathematically exhaustive list of every possible vulnerability source.
- Key access assumptions were checked against official/public docs where feasible: NVD is free with stricter unauthenticated rate limits & higher limits with an API key; GitHub Advisory Database is free/open-source for global advisories; CISA KEV is public; FIRST EPSS is freely available via CSV/API.
- Access / Cost labels are best-effort. Many sources are free to read but may require authentication, registration, support entitlement, API keys, paid tiers, or commercial licenses for higher-volume automation, advanced APIs, or complete data. Recheck terms before production ingestion.
- Link-checking note: treat 403, bot-blocked pages, JavaScript-heavy portals, vendor support portals, rate-limited APIs, & authentication-gated consoles as *restricted/manual-review*, not necessarily broken.

Lifecycle organization:

- **Chapter A** - CVE record intake, identity, schema & governance.
- **Chapter B** - CVE enrichment, exploitability, prioritization & data model.
- **Chapter C** - Weakness taxonomy, attack mapping & AI/ML vulnerability context.
- **Chapter D** - Affectedness truth across packages, OSes, vendors, cloud, ICS & products.
- **Chapter E** - Security supply-chain evidence, SBOM, VEX, provenance & malicious package risk.
- **Chapter F** - Detection, exposure, threat telemetry, validation & remediation operations.
- **Chapter G** - Governance, compliance, assurance, production baselines & final operating model.

Index

- **A. CVE Record Intake, Identity, Schema & Program Governance**
 - [1. Corrections & normalization notes](#)
 - [2. Canonical vulnerability identifiers, CVE records & schemas](#)
 - [2.1 CVE Program - canonical CVE identity](#)
 - [2.2 NVD - CVE enrichment, CPE matching, CVSS & configurations](#)
 - [2.3 Optional CVE meta-mirrors / commercial-community enrichments](#)
 - [2.4 CVE Program governance, project repos, working groups & SADP](#)
 - [2.5 Free CVE lifecycle data feeds, APIs & endpoint references](#)
 - [3. CVE metadata analytical framework, user-story resources, papers & community governance](#)
 - [3.1 CveToad CVE consumer/user-story resources](#)
 - [3.2 CVE/CWE working groups, SIGs & community lists](#)
 - [3.3 Papers, conference programs, talks, training & community material](#)
- **B. CVE Enrichment, Exploitability, Prioritization & Data Model**
 - [4. Exploitation, prioritization, severity & risk scoring](#)
 - [4.1 Known exploited vulnerability sources](#)
 - [4.2 Exploit prediction & scoring](#)

- [4.3 Decision-support frameworks](#)
- [4.4 Public exploit / proof-of-concept / weaponization signals](#)
- **[5. Practical priority hierarchy for ingestion](#)**
 - [5.1 Tier 0 - identifiers & inventory](#)
 - [5.2 Tier 1 - canonical vulnerability records](#)
 - [5.3 Tier 2 - package/ecosystem vulnerability records](#)
 - [5.4 Tier 3 - affectedness, distro & vendor truth](#)
 - [5.5 Tier 4 - severity & prioritization](#)
 - [5.6 Tier 5 - exploitability & weaponization](#)
 - [5.7 Tier 6 - weakness, attack-pattern & AI context](#)
 - [5.8 Tier 7 - detection engineering & validation](#)
- **[6. Recommended canonical data model coverage](#)**
 - [6.1 Vulnerability identity](#)
 - [6.2 Affectedness](#)
 - [6.3 Severity & exploitability](#)
 - [6.4 Environmental impact](#)
 - [6.5 Detection & remediation](#)
- **C. Weakness Taxonomy, Attack Mapping & AI/ML Vulnerability Context**
 - **[7. CWE, CAPEC, ATT&CK, ATLAS & weakness-to-attack mapping](#)**
 - [7.1 CWE - Common Weakness Enumeration](#)
 - [7.2 CAPEC - attack patterns](#)
 - [7.3 MITRE ATT&CK](#)
 - [7.4 AI/ML-specific adversary frameworks](#)
- **D. Affectedness Truth: Package, OS, Vendor, Cloud, ICS & Product Advisories**
 - **[8. Open-source vulnerability databases & package advisory sources](#)**
 - [8.1 OSV ecosystem](#)
 - [8.2 GitHub Advisory Database](#)
 - [8.3 Language & package ecosystem advisory databases](#)
 - **[9. Vendor, OS, distribution, container & package affectedness feeds](#)**
 - [9.1 Scanner-oriented aggregators & vulnerability DB builders](#)
 - [9.2 Red Hat / RHEL / CentOS Stream](#)
 - [9.3 Debian](#)
 - [9.4 Ubuntu / Canonical](#)
 - [9.5 Alpine](#)
 - [9.6 SUSE / openSUSE](#)
 - [9.7 Oracle Linux](#)
 - [9.8 Amazon Linux](#)
 - [9.9 Fedora, AlmaLinux, Rocky, Arch, Gentoo](#)
 - [9.10 Wolfi / Chainguard](#)
 - **[10. Vendor advisories for enterprise impact assessment](#)**
 - [10.1 Major OS, browser & platform vendors](#)
 - [10.2 Enterprise infrastructure vendors](#)
 - [10.3 Cloud provider security bulletins](#)
 - **[11. ICS, OT, IoT, embedded & medical-device sources](#)**
 - [11.1 CISA ICS / medical](#)
 - [11.2 OT / ICS vendor advisories](#)
 - [11.3 IoT / embedded](#)
- **E. Security Supply Chain Evidence: SBOM, VEX, Provenance & Malicious Package Risk**
 - **[12. SBOM, package identity, VEX & advisory exchange standards](#)**
 - [12.1 SBOM standards](#)
 - [12.2 Package & software identity](#)
 - [12.3 Advisory exchange, CSAF & VEX](#)

- 13. Malicious package, supply-chain compromise & package reputation sources
 - 13.1 Malicious package databases
 - 13.2 Package reputation / dependency health
- 14. Source-code, dependency, artifact & build-chain provenance
 - 14.1 Source & artifact provenance
 - 14.2 Dependency inventory & graphing
- **F. Detection, Exposure, Threat Telemetry, Validation & Remediation Operations**
 - 15. Automated vulnerability detection, static analysis, dynamic analysis & research datasets
 - 15.1 SAST / code query engines
 - 15.2 DAST, IAST, fuzzing & dynamic test sources
 - 15.3 Vulnerability-detection research datasets
 - 16. Exposure, internet-facing asset & threat telemetry
 - 16.1 Internet exposure search engines
 - 16.2 Scan/exploitation telemetry
 - 16.3 Attack surface management context
 - 17. Threat intelligence, malware, ransomware & in-the-wild exploitation context
 - 17.1 Major threat research sources
 - 17.2 Malware & IOC repositories
- **G. Governance, Compliance, Assurance, Production Baselines & Final Operating Model**
 - 18. Compliance, baseline configuration, software assurance & exposure severity standards
 - 18.1 Security configuration & benchmarks
 - 18.2 Cloud configuration posture
 - 18.3 Software assurance, secure development, acquisition & NIST publication libraries
 - 19. Minimal source set for production use
 - 20. Final structure for all vulnerability management sources & exposure listings

A. CVE Record Intake, Identity, Schema & Program Governance

1. Corrections & normalization notes

Sl. #	Source Title
1	Project Zero issue tracker migration Link(s) : bugs.chromium.org/p/project-zero/issues/list, project-zero.issues.chromium.org/issues Access / Cost : Free public web access

Sl. #	Source Title
2	Alpine SecDB mirror normalization Link(s) : github.com/alpinelinux/alpine-secdb, secdb.alpinelinux.org Access / Cost : Free / open-source
3	Wolfi / Chainguard feed split Link(s) : packages.cgr.dev/chainguard/security.json, packages.wolfi.dev/os/security.json Access / Cost : Free public feed for Wolfi; Chainguard feed may depend on product entitlement
4	GitHub Advisory APIs Link(s) : docs.github.com/en/graphql/reference/objects#securityadvisory, docs.github.com/en/rest/security-advisories, docs.github.com/en/rest/security-advisories/global-advisories Access / Cost : Free public global advisories; authenticated API / repository advisories may require GitHub account & permissions
5	NVD feeds vs APIs Link(s) : nvd.nist.gov/developers, nvd.nist.gov/vuln/data-feeds Access / Cost : Free public; optional free API key for higher rate limits
6	Link-check allowlist / restricted-source policy Link(s) : Vendor portals, support portals, API consoles, bot-blocked pages, JavaScript-heavy search pages Access / Cost : Not a data source

2. Canonical vulnerability identifiers, CVE records & schemas

2.1 CVE Program - canonical CVE identity

Sl. #	Source Title	Notes
1	CVE.org Link(s) : www.cve.org Access / Cost : Free public	Relevance : Official CVE program portal for CVE IDs, CNA/ADP governance, CVE lookup, & program documentation. Notes & POIs : Canonical governance source, but not always the richest technical source for scoring, affected versions, or exploitability.
2	CVE List v5 - official GitHub mirror/cache Link(s) : github.com/CVEProject/cvelistV5 Access / Cost : Free / open-source public GitHub repo	Relevance : Primary public GitHub cache of CVE v5 JSON records. Useful for local mirroring, batch parsing, & canonical CVE field extraction. Notes & POIs : Records may vary in completeness by CNA. Use with NVD, OSV, vendor advisories, & CISA Vulnrichment for enrichment.
3	CVE Record Format schema - direct JSON schema Link(s) : github.com/CVEProject/cve-schema/blob/main/schema/CVE_Record_Format.json Access / Cost : Free / open-source public GitHub repo	Relevance : Machine-validation schema for CVE v5 records. Required for parser validation & ingestion guardrails. Notes & POIs : Schema correctness does not imply record semantic completeness. Validate schema & still handle missing CNA fields.
4	CVE schema repository Link(s) : github.com/CVEProject/cve-schema Access / Cost : Free / open-source public GitHub repo	Relevance : Contains schema versions, tests, examples, release history, & format evolution. Notes & POIs : Track schema version drift when maintaining long-lived ingestion pipelines.
5	CVE Services API / CVE Program API Link(s) : cveawg.mitre.org/api-docs Access / Cost : Free public docs; API workflows may require role/account for CNA functions	Relevance : Direct CVE lookup & CVE Services API documentation. Useful for targeted lookup workflows. Notes & POIs : API usage may differ from GitHub mirror sync behavior. Use for lookup, not necessarily full mirroring.
6	CVE Authorized Data Publishers - ADPs Link(s) : www.cve.org/ProgramOrganization/ADPs Access / Cost : Free public	Relevance : Lists ADPs that can enrich CVE records beyond CNA-provided content. Notes & POIs : ADP enrichment can add critical assessment context. Treat ADP data as enrichment layered on top of canonical CNA data.
7	CISA Vulnrichment - CVE ADP enrichment Link(s) : github.com/cisagov/vulnrichment Access / Cost : Free / open-source public GitHub repo	Relevance : Provides CISA ADP enrichment of CVE records, including SSVC decision points, & sometimes CWE/CVSS details. Notes & POIs : Useful for prioritization. Coverage may not be universal across all CVEs. Track freshness & missing enrichment states.

2.2 NVD - CVE enrichment, CPE matching, CVSS & configurations

Sl. #	Source Title	Notes
1	NVD home Link(s) : nvd.nist.gov Access / Cost : Free public	Relevance : U.S. government vulnerability-management repository. Provides vulnerability metadata, scoring, product mapping, & references. Notes & POIs : NVD enrichment may lag behind CVE publication or vendor disclosures. Monitor modified dates.
2	NVD CVE API 2.0 Link(s) : nvd.nist.gov/developers/vulnerabilities Access / Cost : Free public; optional free API key for higher rate limits	Relevance : Retrieves CVEs with CVSS, weaknesses, references, CPE configurations, & change history. Notes & POIs : Central for CPE-based product matching. Rate limits & API keys may affect ingestion design.
3	NVD CPE API 2.0	nvd.nist.gov/developers/products
4	NVD Data Feeds	nvd.nist.gov/vuln/data-feeds
5	NVD CVSS resources	nvd.nist.gov/vuln-metrics/cvss
6	NVD CPE Dictionary	nvd.nist.gov/products/cpe
7	NVD API documentation root	nvd.nist.gov/developers
8	NVD CVE Change History API	nvd.nist.gov/developers/vulnerabilities

2.3 Optional CVE meta-mirrors / commercial-community enrichments

These are useful as secondary sources, not canonical replacements.

Sl. #	Source Title	Notes
1	VulnCheck NVD++ Link(s) : www.vulncheck.com/nvd2 Access / Cost : Commercial; limited free/public info may exist	Relevance : Aggregated vulnerability intelligence that can supplement CVE/NVD/KEV workflows. Notes & POIs : Commercial/community enrichment. Validate terms, licensing, API access, & provenance before production use.
2	Vulners Link(s) : vulners.com Access / Cost : Free web search; API/advanced features may require paid plan	Relevance : Vulnerability intelligence aggregator across many advisory & exploit sources. Notes & POIs : Useful for broad search & enrichment. Do not treat as canonical without source provenance.
3	OpenCVE Link(s) : www.opencve.io Access / Cost : Free tier / paid plans	Relevance : CVE monitoring, subscriptions, change tracking, & alerting workflows. Notes & POIs : Useful for monitoring, but canonical ingestion should still pull from upstream CVE/NVD/vendor feeds.
4	CIRCL Vulnerability-Lookup / CVE Search Link(s) : cve.circl.lu Access / Cost : Free public	Relevance : CVE search & enrichment source, historically useful for threat-intel workflows. Notes & POIs : Validate freshness before relying on it. Prefer canonical sources for production scoring.
5	Vulnerability-Lookup GitHub repository Link(s) : github.com/vulnerability-lookup/vulnerability-lookup	Relevance : Correlates vulnerabilities from multiple sources independent of vulnerability IDs & supports coordinated vulnerability disclosure workflows. Notes & POIs : Useful as a CVE/vulnerability correlation

Sl. #	Source Title	Notes
	Access / Cost : Free / open-source public GitHub repo	platform. Treat as a secondary aggregation/enrichment source, not canonical truth.

2.4 CVE Program governance, project repos, working groups & SADP

Sl. #	Source Title	Notes
1	CVEProject GitHub organization Link(s) : github.com/CVEProject Access / Cost : Free public GitHub org	Relevance : Source organization for CVE schema, CVE list mirror, automation working group material, & related program repos. Notes & POIs : Useful for tracking official repository structure & project-level changes.
2	CVE Program Working Groups Link(s) : www.cve.org/programorganization/workinggroups Access / Cost : Free public	Relevance : Official CVE Working Group listing. Notes & POIs : Governance/process context, not a vulnerability feed.
3	CVE/CWE Programs groups.io main page Link(s) : cve-cwe-programs.groups.io/g/main Access / Cost : Public/registration may vary by list	Relevance : Community list hub for CVE/CWE program discussions. Notes & POIs : Use for process context, community discussions, & WG announcements.
4	CVE/CWE Programs groups.io subgroups Link(s) : cve-cwe-programs.groups.io/g/main/subgroups Access / Cost : Public/registration may vary by list	Relevance : Subgroup listing for program working groups. Notes & POIs : Useful for discovering WG-specific list URLs.
5	CVE Consumer Working Group Link(s) : cve-cwe-programs.groups.io/g/ConsumerWG Access / Cost : Public/registration may vary by list	Relevance : CVE consumer feedback, use cases, & schema/process discussions. Notes & POIs : Important for consumer-oriented CVE metadata requirements.
6	CVE Automation Working Group repo Link(s) : github.com/CVEProject/automation-working-group Access / Cost : Free public GitHub repo	Relevance : Automation WG materials, workflows, & implementation discussion artifacts. Notes & POIs : Useful for automation requirements around CVE publication & ingestion.
7	CVE Automation Working Group list Link(s) : cve-cwe-programs.groups.io/g/AWG Access / Cost : Public/registration may vary by list	Relevance : Automation WG mailing list. Notes & POIs : Useful for process & tooling evolution tracking.
8	CVEProject SADP pilot Link(s) : github.com/CVEProject/sadp-pilot Access / Cost : Free public GitHub repo	Relevance : Supplemental ADP/SADP pilot data & artifacts. Notes & POIs : Useful for tracking supplemental vulnerability enrichment experiments.
9	Published SADP Records Link(s) : github.com/CVEProject/sadp-pilot/tree/main/Published%20SADP%20Records	Relevance : Published SADP record corpus. Notes & POIs : Machine-readable/source-

Sl. #	Source Title	Notes
	Access / Cost : Free public GitHub repo path	record context should be validated before ingestion.
10	RogoLabs SADP Tracker Link(s) : rogolabs.github.io/SADP-Tracker Access / Cost : Public site; manually revalidate	Relevance : Community tracker for SADP material. Notes & POIs : Add to link-check allowlist until manually verified.
11	CWE Working Groups & SIGs Link(s) : cwe.mitre.org/community/working_groups.html Access / Cost : Free public	Relevance : CWE working group & SIG context. Notes & POIs : Important for weakness taxonomy evolution, including AI/ML-related CWE work.
12	CVE Services source repository Link(s) : github.com/CVEProject/cve-services Access / Cost : Free public GitHub repo	Relevance : Source repository for the CVE Services API. Notes & POIs : Useful for understanding CVE API implementation behavior, endpoint evolution, & service-side validation semantics.

2.5 Free CVE lifecycle data feeds, APIs & endpoint references

Sl. #	Source Title	Notes
1	CVE Services API - OpenAPI & public CVE record lookup Link(s) : CVE Services API docs , OpenAPI JSON , CVE Services base API Access / Cost : Free public API docs; most write/assignment endpoints require CVE Services credentials; public record lookup is documented as accessible to all.	Relevance : Official lifecycle API surface for CVE ID lookup, CVE record retrieval, CVE reservation, submission, updates, & CNA/Secretariat workflows. Notes & POIs : Primary endpoint family to document: <code>/api/cve/{id}</code> for CVE record lookup, <code>/api/cve-id</code> for CVE ID workflows, & authenticated CNA/Secretariat endpoints for reserve/submit/update operations.
2	CVE Partner List - Root CNAs, CNAs & CNA scope discovery Link(s) : CVE Partner List Access / Cost : Free public web listing; JavaScript rendering/manual review may be needed for automation.	Relevance : Authoritative source for current CVE Program partners, CNA scope boundaries, Root CNAs, & CNA status verification. Notes & POIs : Use to verify CNA status before marking OpenAI, Cloudflare, CrowdStrike, or any vendor as a confirmed CNA. Treat as manual-review source in link-check CI.
3	CVE Program CNA Rules & program process resources Link(s) : CVE Program CNA Rules , CVE Services overview Access / Cost : Free public CVE Program documentation.	Relevance : Defines CNA responsibilities, CVE assignment behavior, record publication expectations, & lifecycle governance rules. Notes & POIs : Use as policy source for CVE reservation, publication, rejection, record updates, scope boundaries, & quality requirements.
4	Google Root CNA / Google Bug Hunters VRP Link(s) : Google Bug Hunters , Google Product Security , CVE Partner List Access / Cost : Free public program pages; CNA role should be verified against the live CVE partner list.	Relevance : Google Root CNA / disclosure path for Google, Android, Chrome, Cloud, AI, & ecosystem issues. Notes & POIs : Keep distinct from Project Zero, Android bulletins, Chrome release posts, Google Cloud bulletins, & OSV.

Sl. #	Source Title	Notes
5	INCIBE-CERT Root CNA / Spanish vulnerability coordination Link(s) : INCIBE-CERT, INCIBE advisories, CVE Partner List Access / Cost : Free public web access; some materials may require Spanish/English page handling.	Relevance : Root CNA / national coordination source relevant to European & Spanish vulnerability coordination. Notes & POIs : Add to CVE governance because CVE Services docs name INCIBE as a Root CNA credential-routing option.
6	JPCERT/CC Root CNA, JVN & MyJVN feeds Link(s) : JPCERT/CC English, JVN English, JVN English RSS, MyJVN API Access / Cost : Free public web/RSS/API documentation; API query construction requires MyJVN parameters.	Relevance : Root CNA / Japan vulnerability coordination source, including Japanese Vulnerability Notes & JVN iPedia-style data access. Notes & POIs : Useful for Asia/Japan disclosure context, multi-vendor coordination, JVN identifiers, & CVE cross-reference workflows.
7	Linux Kernel CNA & linux-cve-announce archive Link(s) : linux-cve-announce archive, Linux kernel security docs, kernel.org Access / Cost : Free public mailing-list archive & documentation.	Relevance : Kernel-specific CVE assignment, disclosure, patch-flow, & affectedness context. Notes & POIs : Track separately from Red Hat, Debian, Ubuntu, SUSE, Amazon Linux, Android, & other downstream distro advisories because distro backports can differ from upstream kernel status.
8	CERT/CC Vulnerability Notes & RSS Link(s) : CERT/CC VULS, CERT/CC VULS RSS Access / Cost : Free public web/RSS access; RSS endpoint should be kept in manual-review allowlist if fetcher blocks it.	Relevance : CVD coordination, multi-vendor vulnerability notes, affected-vendor status, & remediation guidance. Notes & POIs : Add as CNA/coordinator lifecycle source, not only exploit/disclosure context.
9	Microsoft MSRC Security Update Guide / CVRF API Link(s) : MSRC Update Guide, MSRC CVRF updates API, MSRC CVRF document example Access / Cost : Free public web/API access; rate limits & versioned document IDs should be handled by ingestion jobs.	Relevance : Microsoft CNA/product-security source for Microsoft CVEs, affected products, KBs, severity, CVRF-style update metadata, & remediation references. Notes & POIs : Use <code>/updates</code> to discover release document IDs, then fetch specific CVRF documents such as <code>/cvrf/{documentId}</code> for detailed security update metadata.
10	Microsoft Defender Vulnerability Management - list vulnerabilities API Link(s) : List vulnerabilities docs, Vulnerabilities endpoint Access / Cost : Requires Microsoft Defender for Endpoint/Defender Vulnerability Management permissions & bearer token.	Relevance : Asset-aware vulnerability inventory endpoint with CVE ID, CVSS, exploit flags, exposed machines, EPSS, status, & dates. Notes & POIs : Use as enterprise exposure overlay rather than canonical global vulnerability truth.
11	Microsoft Defender Vulnerability Management - per-device software vulnerabilities export Link(s) : Export software vulnerabilities assessment docs, SoftwareVulnerabilitiesByMachine endpoint Access / Cost : Requires Defender API permissions; supports JSON response & via-file export patterns.	Relevance : Maps CVEs to device, software vendor/name/version, OS platform, exploitability level, first/last seen timestamps, & available security updates. Notes & POIs : Best for exposure/affectedness correlation inside an organization. Save snapshots for history because current exports may not preserve historical state.
12	Cisco PSIRT openVuln API Link(s) : Cisco PSIRT openVuln API docs, Cisco	Relevance : Machine-consumable Cisco vulnerability advisories, queryable by advisory ID, CVE ID, bug ID, product type, software version, &

Sl. #	Source Title	Notes
	Security Advisories Access / Cost : Free docs; API use may require Cisco developer/auth workflow depending on endpoint & volume.	timeframe. Notes & POIs : Cisco docs state JSON/XML output & location data for CVRF/CSAF retrieval. Prefer CSAF where available.
13	Cloudflare security disclosure, security.txt & public security research feed Link(s) : Cloudflare security.txt, Cloudflare security policy, Cloudflare security-tag RSS Access / Cost : Free public web/RSS; no dedicated public CVE advisory API confirmed in this pass.	Relevance : Cloudflare product/security disclosure path & security research stream for edge, WAF, DNS, CDN, Workers, Zero Trust, & cloud/network service vulnerability context. Notes & POIs : Treat as disclosure/research feed, not canonical CVE data unless a Cloudflare CVE/advisory record is explicitly published.
14	CrowdStrike public research feed & Falcon Spotlight vulnerability data - restricted Link(s) : CrowdStrike blog feed, CrowdStrike blog, FalconPy docs Access / Cost : Public blog/RSS; Falcon platform vulnerability/Spotlight APIs are authenticated/commercial & not a free public CVE feed.	Relevance : Threat-intel, exploitability, adversary, & enterprise vulnerability-management context; useful for prioritization & exploitation signals. Notes & POIs : Do not list CrowdStrike as a free canonical CVE data feed unless a specific public API/feed is verified.
15	Zero Day Initiative - published & upcoming advisories Link(s) : ZDI published advisories, ZDI upcoming advisories, ZDI published RSS Access / Cost : Free public web/RSS.	Relevance : Pre-disclosure & published vulnerability coordination, exploitability context, vendor disclosure timelines, & ZDI identifiers. Notes & POIs : Useful for tracking vulnerabilities before or around CVE publication. Cross-reference with CVE/NVD/vendor records after publication.
16	Openwall oss-security mailing list & RSS Link(s) : oss-security archive, oss-security RSS Access / Cost : Free public mailing-list archive/RSS.	Relevance : Open-source vulnerability disclosure, CVE requests, embargo release coordination, & early technical discussion. Notes & POIs : High-signal source for OSS CVE lifecycle events. Requires deduplication & careful parsing of threads.
17	Full Disclosure / SecLists CVE-adjacent disclosure feed Link(s) : Full Disclosure archive, Full Disclosure RSS Access / Cost : Free public mailing-list archive/RSS.	Relevance : Public vulnerability disclosures, exploit announcements, advisories, & researcher/vendor coordination context. Notes & POIs : Quality varies. Treat as disclosure signal, not canonical source of affectedness or remediation truth.
18	HackerOne disclosure platform & disclosed reports Link(s) : HackerOne Hacktivity, HackerOne directory Access / Cost : Free public disclosed-report browsing; APIs & program details may require account or platform access.	Relevance : Bug bounty/CVD pipeline source where vulnerabilities can be reported, triaged, disclosed, & sometimes mapped to CVEs. Notes & POIs : Use for lifecycle/disclosure evidence; do not treat every report as CVE-backed or vendor-confirmed without validation.
19	Bugcrowd disclosure platform, VRT & program pages Link(s) : Bugcrowd vulnerability rating taxonomy, Bugcrowd programs Access / Cost : Free public taxonomy/program pages; submissions & details may require account or program access.	Relevance : Bug bounty/CVD triage context & severity normalization for researcher-submitted findings. Notes & POIs : Useful for report-quality & severity context. Not a canonical CVE feed.

Sl. #	Source Title	Notes
20	OpenAI security & bug bounty program Link(s) : OpenAI security & privacy , OpenAI bug bounty announcement , OpenAI Bugcrowd program Access / Cost : Free public security page; Bugcrowd submission workflow; bounty scope/rules apply.	Relevance : AI platform/product vulnerability disclosure path for OpenAI products, APIs, model-serving systems, & AI security issues. Notes & POIs : Add as AI-vendor security/disclosure coverage. Do not mark as confirmed CNA unless verified against the current CVE partner list.
21	GitLab Advisory Database & community advisories Link(s) : GitLab Advisory Database , GitLab advisories-community repo Access / Cost : Free public web/repository access.	Relevance : Package ecosystem advisories, CVE/GHSA/package aliasing, & GitLab security intelligence data. Notes & POIs : Add as secondary package advisory source. Validate ecosystem/version range semantics before automated use.
22	European Union Vulnerability Database - EUVD Link(s) : EUVD portal , ENISA Access / Cost : Free public portal; API/feed endpoint should be verified manually if used for ingestion.	Relevance : European vulnerability database & CVE/EUVD cross-reference context for EU vulnerability governance. Notes & POIs : Add as manual-review lifecycle source until official API/feed endpoints are documented & tested.
23	Open Source Vulnerability Data - VulZoo dataset Link(s) : VulZoo GitHub Access / Cost : Free public GitHub repository.	Relevance : Research dataset aggregating multiple vulnerability intelligence sources with scripts for synchronization, cleaning, relationship mining, & statistics. Notes & POIs : Research/supporting dataset, not canonical operational feed. Useful for model development & source-coverage comparison.
24	CVEfixes vulnerability-fix dataset Link(s) : CVEfixes GitHub Access / Cost : Free public GitHub repository.	Relevance : Dataset linking CVEs with vulnerable code, fixing commits, repositories, & software metrics. Notes & POIs : Useful for CVE lifecycle work around patch links, vulnerable-code evidence, & ML/research datasets.

[Back to Index](#)

3. CVE metadata analytical framework, user-story resources, papers & community governance

3.1 CveToad CVE consumer/user-story resources

Sl. #	Source Title	Notes
1	CveToad CVE Consumer User Story Link(s) : CVE-Consumer_User-Story.md Access / Cost : Free public GitHub repo file	Relevance : Describes a CVE consumer's operational pain points around malformed, inconsistent, incomplete, duplicated, or divergent vulnerability metadata. Notes & POIs : Useful as local user-story evidence for field requirements, ingestion guardrails, validation rules, & normalization priorities.
2	CVE Metadata Elements, Exploitability, & CWE Analytical Framework	Relevance : Analytical framework for CVE metadata fields, exploitability metrics, CWE normalization, & CVSS/CWE correlation.

Sl. #	Source Title	Notes
	Link(s) : CVE-user-story_Description.md Access / Cost : Free public GitHub repo file	Notes & POIs : Good companion to the source inventory; use for implementation requirements & field mapping.
3	CVE metadata framework image Link(s) : CVE_Meta-data_Framework_Table.jpg Access / Cost : Free public GitHub repo file	Relevance : Visual/table artifact for CVE metadata framework. Notes & POIs : Useful for documentation, diagrams, & explanatory material.

3.2 CVE/CWE working groups, SIGs & community lists

Sl. #	Source Title	Notes
1	CWE Working Groups & SIGs Link(s) : cwe.mitre.org/community/working_groups.html Access / Cost : Free public	Relevance : CWE taxonomy governance & working-group context. Notes & POIs : Useful for tracking taxonomy evolution, especially AI/ML weakness classification.
2	CVE Program Working Groups Link(s) : www.cve.org/programorganization/workinggroups Access / Cost : Free public	Relevance : Official CVE WG listing. Notes & POIs : Governance/process source, not vulnerability data.
3	CVE/CWE Programs groups.io main page Link(s) : cve-cwe-programs.groups.io/g/main Access / Cost : Public/registration may vary	Relevance : Main groups.io hub for CVE/CWE program communications. Notes & POIs : Useful for WG discovery & program discussions.
4	CVE/CWE Programs groups.io subgroups Link(s) : cve-cwe-programs.groups.io/g/main/subgroups Access / Cost : Public/registration may vary	Relevance : Subgroup directory. Notes & POIs : Useful for finding active CVE/CWE working groups.
5	CVE Consumer Working Group Link(s) : cve-cwe-programs.groups.io/g/ConsumerWG Access / Cost : Public/registration may vary	Relevance : Consumer WG for CVE data consumers. Notes & POIs : Directly relevant to CVE metadata quality, schema usability, & downstream ingestion pain points.
6	CVE Automation Working Group repo Link(s) : github.com/CVEProject/automation-working-group Access / Cost : Free public GitHub repo	Relevance : Automation WG artifacts & implementation discussion. Notes & POIs : Useful for automated CVE workflows & publication/ingestion changes.
7	CVE Automation Working Group list Link(s) : cve-cwe-programs.groups.io/g/AWG Access / Cost : Public/registration may vary	Relevance : AWG mailing list. Notes & POIs : Useful for automation-focused program discussion.
8	OpenSSF Vulnerability Disclosures Working Group Link(s) : github.com/ossf/wg-vulnerability-disclosures	Relevance : OpenSSF working group focused on improving vulnerability reporting, disclosure, & coordination across open

Sl. #	Source Title	Notes
	Access / Cost : Free public GitHub repo	source. Notes & POIs : Useful for disclosure-process guidance, ecosystem governance, & vulnerability-handling best practices.

3.3 Papers, conference programs, talks, training & community material

Sl. #	Source Title	Notes
1	Accuracy Is Not Enough in Cybersecurity Link(s) : github.com/keerthanap8898/Accuracy-is-Not-Enough-in-Cybersecurity Access / Cost : Free public GitHub repo	Relevance : Blog/article backup focused on cybersecurity prediction, CVE/CVSS/EPSS/user-story context, & VulnCon references. Notes & POIs : Local/reference material, not canonical upstream data. Deduplicate duplicate mentions into one row.
2	FIRST VulnCon 2026 program Link(s) : first.org/conference/vulncon26/program Access / Cost : Free public conference page	Relevance : Vulnerability management, CVE, PSIRT, & disclosure conference program context. Notes & POIs : Good for community/user-story background.
3	FIRST papers - 2026 Link(s) : www.first.org/resources/papers/2026 Access / Cost : Free public	Relevance : FIRST papers & security response material. Notes & POIs : Useful for research & practitioner references.
4	FIRST YouTube channel Link(s) : youtube.com/c/FIRSTdotorg Access / Cost : Free public video channel	Relevance : Official FIRST conference/training/media material. Notes & POIs : Training/reference source, not vulnerability feed.
5	CISA YouTube channel Link(s) : youtube.com/@CISAgov Access / Cost : Free public video channel	Relevance : Official CISA videos, briefings, guidance, & training material. Notes & POIs : Mark as media/reference source.
6	WhiteSec Cyber Security YouTube channel Link(s) : youtube.com/@whiteseccybersecurity Access / Cost : Free public video channel	Relevance : Community cybersecurity training/media material. Notes & POIs : Non-authoritative; validate claims against primary sources.
7	Breachtrace VulnKeeper docs Link(s) : breachtrace.gitbook.io/vulnkeeper Access / Cost : Public docs; manually revalidate	Relevance : Tool/project documentation for vulnerability tracking workflows. Notes & POIs : Community/tooling source; not canonical vulnerability data.
8	LangGuard SCOPE MCP Link(s) : scope-mcp.langguard.ai Access / Cost : Public web tool/service; terms may apply	Relevance : AI/agent compliance & risk-evaluation resource. Notes & POIs : Useful for agent/tool-governance notes in AI security sections.
9	CVE-MCP Link(s) : github.com/jgamblin/CVE-MCP Access / Cost : Free public GitHub repo	Relevance : MCP server/tooling for CVE data via the CVE.org API. Notes & POIs : Useful as experimental CVE-query

Sl. #	Source Title	Notes
		tooling, not as a canonical CVE source. Validate API behavior against official CVE Services docs.

[Back to Index](#)

B. CVE Enrichment, Exploitability, Prioritization & Data Model

4. Exploitation, prioritization, severity & risk scoring

4.1 Known exploited vulnerability sources

Sl. #	Source Title	Note
1	CISA KEV catalog - web Link(s) : www.cisa.gov/known-exploited-vulnerabilities-catalog Access / Cost : Free public	Relevance : Au catalog of kno exploited vulne Critical for prio & remediation Notes & POIs : strong exploita signal but not a complete list o exploited vulne
2	CISA KEV print view Link(s) : www.cisa.gov/known-exploited-vulnerabilities-catalog-print Access / Cost : Free public	Relevance : Hu readable print-KEV view. Notes & POIs : for documenta manual review JSON for autom
3	CISA KEV JSON feed Link(s) : www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json Access / Cost : Free public feed	Relevance : Ma readable KEV f Notes & POIs : automation so KEV ingestion. Monitor dateA due dates.
4	CISA KEV JSON schema Link(s) : www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities_schema.json Access / Cost : Free public feed	Relevance : Sc KEV JSON vali Notes & POIs : ingestion valid Schema chang trigger parser i
5	CISA KEV GitHub mirror Link(s) : github.com/cisagov/kev-data Access / Cost : Free / open-source public GitHub repo	Relevance : Gi mirror of KEV c Notes & POIs : for Git-based c historical track CISA official fe source of truth

Sl. #	Source Title	Note
6	VulnCheck KEV Link(s) : vulncheck.com/kev Access / Cost : Commercial; limited public info may exist	Relevance : Ex KEV-like explo intelligence. Notes & POIs : identical to CIS. Validate definit coverage, licer freshness.
7	Shadowserver reports Link(s) : www.shadowserver.org Access / Cost : Free for eligible organizations; access/registration may be required	Relevance : Int scale exploitat exposure obse Notes & POIs : for exposure/s telemetry. Data aggregated & i access setup.
8	GreyNoise Visualizer Link(s) : viz.greynoise.io Access / Cost : Free tier / paid plans	Relevance : Int scanning/explo noise & actor c Notes & POIs : distinguish ber scanning, mas exploitation, & opportunistic a
9	GreyNoise API docs Link(s) : docs.greynoise.io Access / Cost : Free tier / paid plans; API key required	Relevance : AF based exploita telemetry enrich Notes & POIs : terms, quotas, level can affec automation.

4.2 Exploit prediction & scoring

Sl. #	Source Title	Notes
1	FIRST EPSS overview Link(s) : www.first.org/epss Access / Cost : Free public / open data	Relevance : Exploit Prediction Scoring System. Provides probability-style exploit-likelihood signals. Notes & POIs : EPSS predicts exploitation probability, not impact. Use with CVSS, KEV, exposure, & asset criticality.
2	FIRST EPSS API Link(s) : www.first.org/epss/api Access / Cost : Free public API	Relevance : API endpoint for EPSS scores. Notes & POIs : Useful for daily enrichment. Store score date because EPSS changes over time.
3	FIRST EPSS data & CSV downloads Link(s) : www.first.org/epss/data_stats Access / Cost : Free public data downloads	Relevance : Current & historical EPSS CSV data reference. Notes & POIs : Historical scores are useful for model training & retrospective analysis.
4	Historical EPSS scores GitHub Link(s) : github.com/empiricalsec/epss_scores	Relevance : Daily historical EPSS snapshots.

Sl. #	Source Title	Notes
	Access / Cost : Free public GitHub repo	Notes & POIs : Useful for longitudinal training labels. Validate against FIRST releases.
5	FIRST CVSS Link(s) : www.first.org/cvss Access / Cost : Free public	Relevance : Official CVSS specification home. Notes & POIs : CVSS severity must not be treated as exploit likelihood.
6	FIRST CVSS v4.0 Link(s) : www.first.org/cvss/v4.0/specification-document Access / Cost : Free public	Relevance : CVSS v4.0 specification. Notes & POIs : Newer scoring semantics may not be universally populated across vulnerability records yet.
7	FIRST CVSS v3.1 Link(s) : www.first.org/cvss/v3.1/specification-document Access / Cost : Free public	Relevance : CVSS v3.1 specification. Notes & POIs : Still widely used across CVE/NVD/vendor data.
8	NVD CVSS resources Link(s) : nvd.nist.gov/vuln-metrics/cvss Access / Cost : Free public	Relevance : CVSS calculators & vector references. Notes & POIs : Useful for parsing & validating NVD scoring data.

4.3 Decision-support frameworks

Sl. #	Source Title	Notes
1	CISA SSSVC Link(s) : www.cisa.gov/stakeholder-specific-vulnerability-categorization-ssvc Access / Cost : Free public	Relevance : Stakeholder-Specific Vulnerability Categorization for vulnerability response decisions. Notes & POIs : Useful for decision automation beyond raw severity. Depends on environmental & mission context.
2	CERT/CC SSSVC project Link(s) : github.com/CERTCC/SSVC Access / Cost : Free / open-source public GitHub repo	Relevance : SSSVC model artifacts, examples, & discussions. Notes & POIs : Useful for implementing SSSVC decision trees & decision points.
3	CISA Vulnrichment Link(s) : github.com/cisagov/vulnrichment Access / Cost : Free / open-source public GitHub repo	Relevance : CISA ADP enrichment & SSSVC decision points. Notes & POIs : Coverage is not universal. Preserve missing/null state distinctly from "low risk."
4	CISA Binding Operational Directive 22-01 Link(s) : www.cisa.gov/news-events/directives/bod-22-01-reducing-significant-risk-known-exploited-vulnerabilities Access / Cost : Free public	Relevance : Operational requirement context for KEV remediation. Notes & POIs : Primarily binding for U.S. federal civilian agencies but useful as industry prioritization guidance.
5	CISA Cybersecurity Advisories Link(s) : www.cisa.gov/cybersecurity-advisories Access / Cost : Free public	Relevance : Broader CISA advisory feed. Notes & POIs : Useful for emergent campaigns, vendor alerts, & remediation guidance.

Sl. #	Source Title	Notes
6	CISA Alerts Link(s) : www.cisa.gov/news-events/cybersecurity-advisories Access / Cost : Free public	Relevance : CISA alert/advisory listing. Notes & POIs : May overlap with other CISA pages. Deduplicate by advisory ID/date.

4.4 Public exploit / proof-of-concept / weaponization signals

Sl. #	Source Title	Notes
1	Exploit-DB Link(s) : www.exploit-db.com Access / Cost : Free public	Relevance : Public exploit archive. Strong signal for PoC availability. Notes & POIs : Public PoC does not always mean reliable weaponization; verify exploit quality & target version.
2	SearchSploit Link(s) : www.exploit-db.com/searchsploit Access / Cost : Free / open-source tool	Relevance : CLI interface for Exploit-DB. Notes & POIs : Useful for local workflows & offline search.
3	Exploit-DB GitLab mirror Link(s) : gitlab.com/exploit-database/exploitdb Access / Cost : Free public GitLab repo	Relevance : Git mirror of Exploit-DB content. Notes & POIs : Useful for local indexing & diffing.
4	Metasploit Framework Link(s) : github.com/rapid7/metasploit-framework Access / Cost : Free / open-source public GitHub repo; commercial Rapid7 products separate	Relevance : Exploit framework containing modules, payloads, & auxiliary checks. Notes & POIs : A Metasploit module is a stronger operationalization signal than a bare PoC.
5	Metasploit exploit modules Link(s) : github.com/rapid7/metasploit-framework/tree/master/modules/exploits Access / Cost : Free / open-source public GitHub repo	Relevance : Practical signal that a vulnerability has weaponized exploit implementation. Notes & POIs : Module maturity, reliability, & target coverage vary.
6	Packet Storm Security exploits Link(s) : packetstormsecurity.com/files/tags/exploit Access / Cost : Free public; may bot-block automated fetchers	Relevance : Public exploit & advisory archive. Notes & POIs : Quality & metadata normalization vary; cross-reference CVE IDs. Mark bot-blocked fetches as restricted/manual-review.
7	VulnCheck Exploit Database Query Console Link(s) : console.vulncheck.com Access / Cost : Auth-gated / commercial; limited public access may exist	Relevance : Exploit intelligence query console. Notes & POIs : Treat as restricted/manual-review in CI. Validate licensing & provenance before production use.
8	Vulners Exploit Catalog Link(s) : vulners.com/search Access / Cost : Free web search; API/advanced features may require paid plan	Relevance : Broad exploit/advisory search catalog. Notes & POIs : Secondary enrichment. Do not treat as canonical without upstream provenance.

Sl. #	Source Title	Notes
9	Project Zero blog Link(s) : projectzero.google Access / Cost : Free public	Relevance : High-quality root-cause & exploitation writeups. Notes & POIs : Excellent for model features around exploitability primitives & bug classes.
10	Project Zero issue tracker - current Link(s) : project-zero.issues.chromium.org/issues Access / Cost : Free public; some issue details may be restricted before disclosure	Relevance : Current Project Zero issue tracker. Notes & POIs : Good for disclosure timelines & technical details.
11	Project Zero issue tracker - old/historical Link(s) : bugs.chromium.org/p/project-zero/issues/list Access / Cost : Free public historical access where still available	Relevance : Historical Project Zero issue tracker link. Notes & POIs : Keep for old references; prefer current /issues tracker when available.
12	CERT/CC Vulnerability Notes Database Link(s) : www.kb.cert.org/vuls Access / Cost : Free public	Relevance : Coordinated disclosure context, affected vendors, technical notes, & remediation. Notes & POIs : Often useful when multiple vendors/products are affected.
13	Rapid7 AttackerKB Link(s) : attackerkb.com Access / Cost : Free public content; some Rapid7 ecosystem features may be commercial	Relevance : Exploitability & attacker-value context. Notes & POIs : Community/commercial signals should be weighted with provenance & recency.
14	Nuclei templates Link(s) : github.com/projectdiscovery/nuclei-templates Access / Cost : Free / open-source public GitHub repo	Relevance : Exposed-condition detection templates. Useful for scanning internet-facing assets. Notes & POIs : Template presence is a practical detection signal, not proof of vulnerability unless executed correctly.
15	ProjectDiscovery Nuclei Link(s) : github.com/projectdiscovery/nuclei Access / Cost : Free / open-source public GitHub repo; commercial ProjectDiscovery offerings separate	Relevance : Template-based vulnerability & exposure scanner. Notes & POIs : Detection accuracy depends on template quality, target context, & scanner configuration.
16	Horizon3.ai research Link(s) : horizon3.ai/attack-research Access / Cost : Free public research; commercial products separate	Relevance : PoC & attack-path writeups. Notes & POIs : Useful for exploitability context & reproduction details.
17	watchTowr Labs Link(s) : labs.watchtowr.com Access / Cost : Free public research; commercial services separate	Relevance : Vulnerability research & exploitation details. Notes & POIs : Research source; verify exact affected versions & mitigations.
18	Assetnote research Link(s) : www.assetnote.io/resources/research	Relevance : Exploit research & vulnerability detection signatures. Notes & POIs : Useful for detection

Sl. #	Source Title	Notes
	Access / Cost : Free public research; commercial services separate	engineering & exposed attack surface context.
19	Breachtrace VulnKeeper docs Link(s) : breachtrace.gitbook.io/vulnkeeper Access / Cost : Public docs; manually revalidate	Relevance : Community/tooling documentation for vulnerability tracking. Notes & POIs : Treat as non-canonical & keep in manual-review allowlist until verified.

[Back to Index](#)

5. Practical priority hierarchy for ingestion

5.1 Tier 0 - identifiers & inventory

Sl. #	Source Title	Notes
1	SBOM Link(s) : cyclonedx.org/specification/overview , spdx.dev/specifications Access / Cost : Free / open standards	Relevance : Inventory foundation for matching components to vulnerabilities. Notes & POIs : Without accurate inventory, vulnerability matching is incomplete or noisy.
2	Package identity Link(s) : csrc.nist.gov/projects/software-identification-swid , github.com/package-url/purl-spec , nvd.nist.gov/products/cpe Access / Cost : Free public / open standards	Relevance : Component identity across package, product, & installed software domains. Notes & POIs : Use PURL for packages, CPE for products/platforms, SWID for installed software identity.
3	Asset exposure Link(s) : search.censys.io , www.shodan.io Access / Cost : Free tiers / paid plans	Relevance : Determines whether vulnerable assets are externally reachable. Notes & POIs : Combine with internal CMDB, cloud inventory, & authenticated scans.
4	Artifact provenance Link(s) : in-toto.io , slsa.dev , www.sigstore.dev Access / Cost : Free / open-source / open standards	Relevance : Validates build-chain integrity & artifact authenticity. Notes & POIs : Helps distinguish vulnerable dependency risk from supply-chain tampering risk.

5.2 Tier 1 - canonical vulnerability records

Sl. #	Source Title	Notes
1	CVE List v5 Link(s) : github.com/CVEProject/cvelistV5 Access / Cost : Free public GitHub repo	Relevance : Canonical CVE record mirror. Notes & POIs : Core identity source.
2	CVE schema Link(s) : github.com/CVEProject/cve-schema Access / Cost : Free public GitHub repo	Relevance : Schema validation for CVE records. Notes & POIs : Use for parser correctness.
3	CVE Services API Link(s) : cveawg.mitre.org/api-docs Access / Cost : Free public docs; CNA functions may require role/account	Relevance : Direct programmatic CVE lookup. Notes & POIs : Useful for targeted CVE access.
4	NVD CVE API Link(s) : nvd.nist.gov/developers/vulnerabilities Access / Cost : Free public; optional free API key for higher rate limits	Relevance : CVSS/CPE/CWE/reference enrichment. Notes & POIs : Core enrichment source.
5	NVD CPE API Link(s) : nvd.nist.gov/developers/products Access / Cost : Free public; optional free API key for higher rate limits	Relevance : CPE dictionary & product matching. Notes & POIs : Important for product-level mapping.
6	NVD data feeds Link(s) : nvd.nist.gov/vuln/data-feeds Access / Cost : Free public	Relevance : Bulk NVD feed access. Notes & POIs : Useful for bootstrapping.
7	CISA Vulnrichment Link(s) : github.com/cisagov/vulnrichment Access / Cost : Free public GitHub repo	Relevance : CISA ADP enrichment & SSVC data. Notes & POIs : Prioritization enrichment.

5.3 Tier 2 - package/ecosystem vulnerability records

Sl. #	Source Title	Notes
1	OSV full database Link(s) : google.github.io/osv.dev/data/#full-database-download Access / Cost : Free public	Relevance : Local mirror of OSS vulnerability records. Notes & POIs : Best for high-volume package matching.
2	OSV API Link(s) : google.github.io/osv.dev/post-v1-query Access / Cost : Free public API	Relevance : Online vulnerability lookup by package/version/commit/ID. Notes & POIs : Good for targeted lookups.

Sl. #	Source Title	Notes
3	GitHub Advisory Database Link(s) : github.com/advisories Access / Cost : Free public	Relevance : GHSA/CVE/malware advisory records. Notes & POIs : Preserve aliases.
4	GitHub Advisory Database repo Link(s) : github.com/github/advisory-database Access / Cost : Free / open-source public GitHub repo	Relevance : Raw advisory data for local ingestion. Notes & POIs : Useful for mirroring.
5	Go vuln DB Link(s) : vuln.go.dev Access / Cost : Free public	Relevance : Official Go vulnerability database. Notes & POIs : Go- specific affectedness.
6	RustSec Link(s) : rustsec.org Access / Cost : Free public / open-source ecosystem	Relevance : Rust advisory ecosystem. Notes & POIs : Rust crate-specific advisories.
7	PyPA advisory DB Link(s) : github.com/pypa/advisory-database Access / Cost : Free public GitHub repo	Relevance : Python advisory source. Notes & POIs : Python/PyPI coverage.
8	FriendsOfPHP Link(s) : github.com/FriendsOfPHP/security-advisories Access / Cost : Free public GitHub repo	Relevance : PHP Composer advisories. Notes & POIs : Composer-specific.
9	RubySec Link(s) : github.com/rubysec/ruby-advisory-db Access / Cost : Free public GitHub repo	Relevance : RubyGems advisories. Notes & POIs : Ruby ecosystem.
10	OSS Index Link(s) : ossindex.sonatype.org Access / Cost : Free tier / API terms; commercial Sonatype products separate	Relevance : Package vulnerability intelligence. Notes & POIs : Secondary enrichment.
11	Packagist API Link(s) : packagist.org/apidoc#list-security-advisories Access / Cost : Free public API docs / public API	Relevance : Composer advisory API. Notes & POIs : Direct PHP ecosystem source.

5.4 Tier 3 - affectedness, distro & vendor truth

Sl. #	Source Title
1	Red Hat Security Data Link(s) : access.redhat.com/security/data Access / Cost : Free public data; support content may require subscription

Sl. #	Source Title
2	Debian Security Tracker Link(s) : security-tracker.debian.org Access / Cost : Free public
3	Ubuntu OVAL / OSV / OpenVEX Link(s) : github.com/canonical/ubuntu-security-notices , ubuntu.com/security/oval , ubuntu.com/security/vex Access / Cost : Free public
4	Alpine SecDB Link(s) : secdb.alpinelinux.org Access / Cost : Free public
5	SUSE CSAF / OVAL Link(s) : www.suse.com/support/security/csaf , www.suse.com/support/security/oval Access / Cost : Free public
6	Oracle Linux OVAL / errata Link(s) : linux.oracle.com/errata , linux.oracle.com/security/oval Access / Cost : Free public
7	Amazon Linux ALAS Link(s) : alas.aws.amazon.com Access / Cost : Free public
8	AlmaLinux / Rocky / Fedora / Arch / Gentoo Link(s) : bodhi.fedoraproject.org/updates/?type=security , errata.almalinux.org , errata.build.resf.org , security.archlinux.org , security.gentoo.org/glsa Access / Cost : Free public
9	Wolfi / Chainguard Link(s) : github.com/wolfi-dev/advisories , packages.cgr.dev/chainguard/security.json , packages.wolfi.dev/os/se Access / Cost : Wolfi free public; Chainguard feed may relate to commercial product scope
10	Vendor advisories Link(s) : helpx.adobe.com/security.html , msrc.microsoft.com/update-guide , security.paloaltonetworks.com , sec.cloudapps.cisco.com/security/center/publicationListing.x , support.apple.com/100100 , support.broadcom.com/web/ecx/security-advisory , support.citrix.com/securitybulletins , support.sap.com/en/my-support/knowledge-base/security-notes-news.html , www.atlassian.com/trust/security/advisories , www.fortiguard.com/psirt , forums.ivanti.com/s/security-advisory , www.oracle.com/security-alerts

Sl. #	Source Title
	Access / Cost : Mostly free public advisories; some vendors require support accounts/subscriptions for full data downloads

5.5 Tier 4 - severity & prioritization

Sl. #	Source Title	Notes
1	CVSS v3.1/v4.0 Link(s) : www.first.org/cvss/v3.1/specification-document , www.first.org/cvss/v4.0/specification-document Access / Cost : Free public	Relevance : Standard severity scoring. Notes & POIs : Severity is not exploit likelihood.
2	EPSS Link(s) : www.first.org/epss Access / Cost : Free public data/API	Relevance : Exploit likelihood prediction. Notes & POIs : Temporal; store score date.
3	KEV Link(s) : www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json Access / Cost : Free public feed	Relevance : Known exploited vulnerability signal. Notes & POIs : Strong but incomplete exploited-in-the-wild signal.
4	SSVC Link(s) : github.com/CERTCC/SSVC , www.cisa.gov/stakeholder-specific-vulnerability-categorization-ssvc Access / Cost : Free public / open-source	Relevance : Decision support for remediation urgency. Notes & POIs : Requires environmental/mission context.
5	CISA Vulnrichment Link(s) : github.com/cisagov/vulnrichment Access / Cost : Free public GitHub repo	Relevance : SSVC & enrichment data. Notes & POIs : Coverage varies.
6	Vendor exploited-in-the-wild flags Link(s) : msrc.microsoft.com/update-guide , support.apple.com/en-us/100100 , www.oracle.com/security-alerts Access / Cost : Free public, though product support details may vary	Relevance : Vendor-provided exploitation status. Notes & POIs : Often product-specific & time-sensitive.
7	Patch availability & fixed-version feeds Link(s) : access.redhat.com/security/data , github.com/canonical/ubuntu-security-notices , security-tracker.debian.org/tracker/data/json Access / Cost : Free public data; some vendor support may require subscription	Relevance : Determines whether remediation exists. Notes & POIs : Patch availability varies by distro/release/product.
8	Environmental context Link(s) : docs.greynoise.io , search.censys.io , www.shodan.io Access / Cost : Free tiers / paid plans	Relevance : Internet exposure, asset criticality, privilege boundary, & data sensitivity determine

Sl. #	Source Title	Notes
		real impact. Notes & POIs : Must be joined with internal asset inventory & controls.

5.6 Tier 5 - exploitability & weaponization

Sl. #	Source Title	Notes
1	Exploit-DB Link(s) : www.exploit-db.com Access / Cost : Free public	Relevance : Public exploit availability. Notes & POIs : Verify target versions & exploit reliability.
2	Metasploit modules Link(s) : github.com/rapid7/metasploit-framework/tree/master/modules/exploits Access / Cost : Free / open-source	Relevance : Weaponized exploit modules. Notes & POIs : Strong operationalization signal.
3	Packet Storm Link(s) : packetstormsecurity.com/files/tags/exploit Access / Cost : Free public	Relevance : Exploit archive. Notes & POIs : Metadata quality varies.
4	Project Zero Link(s) : projectzero.google , project-zero.issues.chromium.org Access / Cost : Free public; some issues may be restricted pre-disclosure	Relevance : Root-cause & exploitability research. Notes & POIs : High-quality technical details.
5	CERT/CC VU notes Link(s) : www.kb.cert.org/vuls Access / Cost : Free public	Relevance : Coordinated disclosure & affected vendor context. Notes & POIs : Useful for ecosystem-wide vulns.
6	Rapid7 AttackerKB Link(s) : attackerkb.com Access / Cost : Free public content; commercial Rapid7 offerings separate	Relevance : Attacker value & exploitability context. Notes & POIs : Secondary enrichment.
7	GreyNoise Link(s) : docs.greynoise.io , viz.greynoise.io Access / Cost : Free tier / paid plans	Relevance : Internet exploitation/scanning telemetry. Notes & POIs : Distinguishes noise from activity.
8	Shadowserver Link(s) : dashboard.shadowserver.org , www.shadowserver.org Access / Cost : Free for eligible organizations; registration may be required	Relevance : Exposure & threat telemetry. Notes & POIs : Access & reporting terms vary.
9	Nuclei templates	Relevance : Detection templates for exposed vulnerabilities.

Sl. #	Source Title	Notes
	Link(s) : github.com/projectdiscovery/nuclei-templates Access / Cost : Free / open-source	Notes & POIs : Template presence is not proof of exposure.
10	Vendor emergency advisories Link(s) : www.cisa.gov/cybersecurity-advisories , www.fortiguard.com/psirt , forums.ivanti.com/s/security-advisory Access / Cost : Free public	Relevance : Emergency/active exploitation guidance. Notes & POIs : Highly time-sensitive; monitor frequently.

5.7 Tier 6 - weakness, attack-pattern & AI context

Sl. #	Source Title	Notes
1	CWE Link(s) : cwe.mitre.org Access / Cost : Free public	Relevance : Weakness taxonomy. Notes & POIs : CVE-to-CWE mappings can be broad or missing.
2	CAPEC Link(s) : capec.mitre.org Access / Cost : Free public	Relevance : Attack-pattern taxonomy. Notes & POIs : Maps weaknesses to attack patterns.
3	ATT&CK Enterprise Link(s) : attack.mitre.org/matrices/enterprise Access / Cost : Free public	Relevance : Enterprise adversary behavior taxonomy. Notes & POIs : More post-exploitation than CVE-specific.
4	ATT&CK STIX Link(s) : github.com/mitre-attack/attack-stix-data Access / Cost : Free public GitHub repo	Relevance : Machine-readable ATT&CK data. Notes & POIs : Best for ingestion.
5	MITRE CTI repo Link(s) : github.com/mitre/cti Access / Cost : Free public GitHub repo	Relevance : MITRE STIX data repository. Notes & POIs : Useful for CTI graphing.
6	MITRE ATLAS Link(s) : atlas.mitre.org Access / Cost : Free public	Relevance : AI adversary tactics & techniques. Notes & POIs : Directly relevant to AI/ML systems.
7	OWASP LLM Top 10 Link(s) : owasp.org/www-project-top-10-for-large-language-model-applications Access / Cost : Free public / open community	Relevance : LLM application vulnerability taxonomy. Notes & POIs : Good for AI appsec.
8	OWASP ML Security Top 10 Link(s) : owasp.org/www-project-machine-learning-security-top-10	Relevance : ML security risk taxonomy.

Sl. #	Source Title	Notes
	Access / Cost : Free public / open community	Notes & POIs : Complements ATLAS.
9	NIST AI RMF & NIST AI 600-1 Link(s) : nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf , www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence Access / Cost : Free public	Relevance : AI risk management & GenAI risk profile. Notes & POIs : Governance/risk context, not vuln feed.

5.8 Tier 7 - detection engineering & validation

Sl. #	Source Title
1	CodeQL Link(s) : codeql.github.com Access / Cost : Free for many open-source uses; commercial GitHub Advanced Security for many enterprise/private repos
2	Semgrep Link(s) : semgrep.dev Access / Cost : Free/open-source CLI; commercial products available
3	Joern Link(s) : joern.io Access / Cost : Free / open-source
4	Infer Link(s) : fbinfer.com Access / Cost : Free / open-source
5	Sonar rules Link(s) : rules.sonarsource.com Access / Cost : Free public catalog; commercial Sonar products available
6	Nuclei templates Link(s) : github.com/projectdiscovery/nuclei-templates Access / Cost : Free / open-source
7	OSS-Fuzz Link(s) : google.github.io/oss-fuzz Access / Cost : Free for eligible open-source projects
8	SARD / Juliet Link(s) : samate.nist.gov/SARD , samate.nist.gov/SARD/test-suites/112 Access / Cost : Free public

Sl. #	Source Title
9	Vulnerability datasets Link(s) : github.com/DLVulDet/PrimeVul , github.com/lcyrockton/MegaVul , github.com/ZeoVan/MSR_20_Code_project/CVEfixes , github.com/tuhh-softsec/vul4j , github.com/wagner-group/diverse vul , sites.google.com/view/d Access / Cost : Mostly free public research datasets; verify license individually

[Back to Index](#)

6. Recommended canonical data model coverage

A complete vulnerability impact system should be able to ingest or derive the following fields.

6.1 Vulnerability identity

Sl. #	Source Title	Notes
1	CVE ID Link(s) : github.com/CVEProject/cvelistV5 , www.cve.org Access / Cost : Free public	Relevance : Canonical vulnerability identifier. Notes & POIs : Not all advisories have CVEs immediately.
2	GHSA ID Link(s) : github.com/advisories Access / Cost : Free public	Relevance : GitHub Security Advisory identifier. Notes & POIs : May exist without CVE.
3	OSV ID Link(s) : osv.dev Access / Cost : Free public	Relevance : OSV vulnerability identifier. Notes & POIs : Links package-specific affectedness & aliases.
4	Vendor advisory ID Link(s) : msrc.microsoft.com/update-guide , www.oracle.com/security-alerts Access / Cost : Mostly free public; some support details may require entitlement	Relevance : Vendor-specific advisory identifier. Notes & POIs : Often most authoritative for product-specific truth.
5	CWE ID Link(s) : cwe.mitre.org Access / Cost : Free public	Relevance : Weakness class identifier. Notes & POIs : Quality of mapping varies.
6	CAPEC ID Link(s) : capec.mitre.org Access / Cost : Free public	Relevance : Attack-pattern identifier. Notes & POIs : Useful for attack mechanism mapping.
7	ATT&CK technique ID Link(s) : attack.mitre.org/matrices/enterprise Access / Cost : Free public	Relevance : Adversary technique identifier. Notes & POIs : Useful for detection/response mapping.

Sl. #	Source Title	Notes
8	ATLAS technique ID Link(s) : atlas.mitre.org/techniques Access / Cost : Free public	Relevance : AI/ML adversary technique identifier. Notes & POIs : Relevant for AI systems.
9	Alias graph Link(s) : github.com/CVEProject/cvelistV5 , github.com/advisories , osv.dev Access / Cost : Free public	Relevance : Maps CVE/GHSA/OSV/vendor aliases. Notes & POIs : Crucial for deduplication & correlation.

6.2 Affectedness

Sl. #	Source Title	Notes
1	Product name Link(s) : nvd.nist.gov/products/cpe Access / Cost : Free public	Relevance : Identifies vulnerable products. Notes & POIs : Normalize against CPE/PURL/vendor data.
2	Vendor Link(s) : www.cve.org Access / Cost : Free public	Relevance : Vendor/product attribution. Notes & POIs : Vendor naming can differ across sources.
3	CPE Link(s) : nvd.nist.gov/developers/products Access / Cost : Free public; optional free API key for higher rate limits	Relevance : Product/platform matching. Notes & POIs : Imprecise for many OSS packages.
4	PURL Link(s) : github.com/package-url/purl-spec Access / Cost : Free / open-source	Relevance : Package identity. Notes & POIs : Prefer for package ecosystem matching.
5	Package ecosystem Link(s) : osv.dev/list Access / Cost : Free public	Relevance : Defines package namespace & version rules. Notes & POIs : Version semantics are ecosystem-specific.
6	Package name Link(s) : deps.dev Access / Cost : Free public	Relevance : Dependency identity. Notes & POIs : Normalize casing & namespace rules.
7	Affected version range Link(s) : ossf.github.io/osv-schema Access / Cost : Free public / open-source	Relevance : Expresses vulnerable versions. Notes & POIs : Range interpretation must respect ecosystem semantics.
8	Fixed version Link(s) : github.com/advisories , osv.dev Access / Cost : Free public	Relevance : Remediation target. Notes & POIs : Distro fixed versions may differ due to backports.

Sl. #	Source Title	Notes
9	Introduced version / commit Link(s) : ossf.github.io/osv-schema Access / Cost : Free public / open-source	Relevance : Determines when vulnerability entered codebase. Notes & POIs : Not always available.
10	Last affected version Link(s) : ossf.github.io/osv-schema Access / Cost : Free public / open-source	Relevance : Helps determine affected version bounds. Notes & POIs : Validate with vendor feeds.
11	Backport status Link(s) : access.redhat.com/security/data , security-tracker.debian.org , ubuntu.com/security/cves Access / Cost : Mostly free public; some Red Hat support details may require subscription	Relevance : Determines if a distro package is patched despite upstream version appearing vulnerable. Notes & POIs : Essential for reducing false positives.
12	VEX status Link(s) : github.com/openvex/spec , www.csaf.io Access / Cost : Free / open-source standards	Relevance : Represents affected, not affected, fixed, or under investigation. Notes & POIs : Preserve justification & author provenance.
13	Justification for not affected Link(s) : github.com/openvex/spec Access / Cost : Free / open-source	Relevance : Explains why a product is not affected. Notes & POIs : Key for trust & auditability.
14	Distro/package release channel Link(s) : packages.fedoraproject.org , pkgs.alpinelinux.org/packages Access / Cost : Free public	Relevance : Tracks package release stream. Notes & POIs : Channel differences can affect fix availability.

6.3 Severity & exploitability

Sl. #	Source Title	Notes
1	CVSS v2/v3/v4 vector Link(s) : www.first.org/cvss Access / Cost : Free public	Relevance : Structured severity vector. Notes & POIs : Use vector, not only numeric score.
2	CVSS base/temporal/environmental score Link(s) : nvd.nist.gov/vuln-metrics/cvss Access / Cost : Free public	Relevance : Severity scoring. Notes & POIs : Environmental score should be computed with local context.

Sl. #	Source Title	Notes
3	EPSS score Link(s) : www.first.org/epss Access / Cost : Free public data/API	Relevance : Exploit likelihood. Notes & POIs : Temporal; store score date.
4	EPSS percentile Link(s) : www.first.org/epss/data_stats Access / Cost : Free public data downloads	Relevance : Relative exploit-likelihood ranking. Notes & POIs : Useful for prioritization across backlog.
5	KEV membership Link(s) : www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json Access / Cost : Free public feed	Relevance : Known exploited vulnerability marker. Notes & POIs : Strong exploitation evidence.
6	KEV date added Link(s) : www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json Access / Cost : Free public feed	Relevance : Temporal exploitation/prioritization signal. Notes & POIs : Use for SLA & trend analysis.
7	Known ransomware usage Link(s) : www.ransomware.live Access / Cost : Free public	Relevance : Ransomware exploitation context. Notes & POIs : Attribution & mapping quality vary.
8	Public exploit available Link(s) : www.exploit-db.com Access / Cost : Free public	Relevance : PoC/exploit availability. Notes & POIs : Verify reliability & version applicability.
9	Metasploit module available Link(s) : github.com/rapid7/metasploit-framework/tree/master/modules/exploits Access / Cost : Free / open-source	Relevance : Weaponized exploit implementation. Notes & POIs : Stronger than generic PoC signal
10	Nuclei template available Link(s) : github.com/projectdiscovery/nuclei-templates Access / Cost : Free / open-source	Relevance : Detection template availability. Notes & POIs : Indicate detectable exposure, not confirmed vulnerability.
11	GreyNoise observed scanning Link(s) : viz.greynoise.io Access / Cost : Free tier / paid plans	Relevance : Internet scanning/exploitation telemetry. Notes & POIs : Helps prioritize exposed services.
12	Shadowserver observed exposure Link(s) : dashboard.shadowserver.org	Relevance : Internet-scale exposure telemetry.

Sl. #	Source Title	Notes
	Access / Cost : Free for eligible organizations; registration may be required	Notes & POIs : Access may require registration/eligibility.
13	CISA SSVC decision points Link(s) : github.com/cisagov/vulnrichment Access / Cost : Free public GitHub repo	Relevance : Decision support enrichment. Notes & POIs : Useful for prioritization workflows.
14	Vendor exploitation status Link(s) : msrc.microsoft.com/update-guide , security.paloaltonetworks.com , support.apple.com/en-us/100100 Access / Cost : Free public	Relevance : Vendor-provided exploitation notes. Notes & POIs : Time-sensitive & product-specific.
15	Patch availability Link(s) : access.redhat.com/security/data , security-tracker.debian.org , ubuntu.com/security/notices Access / Cost : Mostly free public; some vendor support details may require subscription	Relevance : Determines if a fix exists. Notes & POIs : Patch availability varies by release stream.
16	Workaround availability Link(s) : www.cisa.gov/cybersecurity-advisories , www.kb.cert.org/vuls Access / Cost : Free public	Relevance : Temporary mitigation when patching is not available Notes & POIs : Workarounds may reduce but not eliminate risk.

6.4 Environmental impact

Sl. #	Source Title	Notes
1	Asset criticality	www.cisecurity.org/controls
2	Internet exposure	search.censys.io , www.shodan.io
3	Network reachability	nmap.org
4	Authentication required	www.first.org/cvss
5	Privilege required	www.first.org/cvss
6	User interaction required	www.first.org/cvss
7	Exploit preconditions	projectzero.google , www.kb.cert.org/vuls
8	Data sensitivity	www.cisecurity.org/controls
9	Compensating controls	public.cyber.mil/stigs , www.cisecurity.org/cis-benchmarks
10	Runtime configuration	docs.dependencytrack.org/datasources/overview
11	Feature/module enabled	github.com/openvex/spec
12	Cloud account/project/environment	github.com/prowler-cloud/prowler
13	Blast radius	github.com/salesforce/cloudsplaining
14	Business process ownership	www.cisecurity.org/controls

6.5 Detection & remediation

Sl. #	Source Title	
1	Scanner finding ID Link(s) : dependencytrack.org , github.com/anchore/grype , trivy.dev/docs/latest/scanner/vulnerability Access / Cost : Free / open-source core tools; commercial support/products may exist	Relev findin Note: scanr repro
2	Detection method Link(s) : codeql.github.com , github.com/projectdiscovery/nuclei , owasp.org/www-project-top-ten Access / Cost : Mixed: free/open-source, with some commercial tiers	Relev findin packa laC, c Note: meth positi
3	Confidence Link(s) : github.com/openvex/spec Access / Cost : Free / open-source	Relev rank 1 Note: sourc confi
4	False-positive reason Link(s) : github.com/openvex/spec Access / Cost : Free / open-source	Relev matcl or aff Note: is key
5	Fix version Link(s) : github.com/advisories , osv.dev Access / Cost : Free public	Relev versio Note: versio backp
6	Patch advisory Link(s) : access.redhat.com/security/data , ubuntu.com/security/notices , www.debian.org/security Access / Cost : Mostly free public; some Red Hat support details may require subscription	Relev vendo Note: sourc reme
7	Mitigation Link(s) : www.cisa.gov/cybersecurity-advisories , www.kb.cert.org/vuls Access / Cost : Free public	Relev comp Note: be pa
8	Workaround Link(s) : www.kb.cert.org/vuls Access / Cost : Free public	Relev reme unava Note: repla
9	Exploit detection signatures Link(s) : github.com/SigmaHQ/sigma , github.com/VirusTotal/yara , github.com/projectdiscovery/nuclei-templates Access / Cost : Free / open-source public GitHub repos	Relev for ex comp Note: signa high-
10	Regression test	Relev vulne

Sl. #	Source Title	
	Link(s) : github.com/google/oss-fuzz , google.github.io/oss-fuzz Access / Cost : Free / open-source; OSS-Fuzz service for eligible OSS projects	not re Note: SDLC
11	Verification command Link(s) : github.com/anchore/grype , github.com/aquasecurity/trivy-db , github.com/projectdiscovery/nuclei Access / Cost : Free / open-source	Relev to ver reme Note: repea
12	SLA due date Link(s) : www.cisa.gov/news-events/directives/bod-22-01-reducing-significant-risk-known-exploited-vulnerabilities , www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json Access / Cost : Free public	Relev deadl sever busin Note: policy

[Back to Index](#)

C. Weakness Taxonomy, Attack Mapping & AI/ML Vulnerability Context

7. CWE, CAPEC, ATT&CK, ATLAS & weakness-to-attack mapping

7.1 CWE - Common Weakness Enumeration

Sl. #	Source Title	Notes
1	CWE home Link(s) : cwe.mitre.org Access / Cost : Free public	Relevance : Common Weakness Enumeration root. Provides standardized weakness taxonomy. Notes & POIs : CVE-to-CWE mappings are sometimes missing, broad, or imprecise.
2	CWE downloads Link(s) : cwe.mitre.org/data/downloads.html Access / Cost : Free public downloads	Relevance : XML, CSV, archive bundles, & views for machine ingestion. Notes & POIs : Use downloadable structural data for robust taxonomy ingestion.
3	CWE latest PDF Link(s) : cwe.mitre.org/data/published/cwe_latest.pdf Access / Cost : Free public PDF	Relevance : PDF publication of latest CWE content. Notes & POIs : Better for manual reference than automated ingestion.
4	CWE reports Link(s) : cwe.mitre.org/data/reports.html Access / Cost : Free public	Relevance : Reports & curated views of CWE data. Notes & POIs : Useful for understanding categories, views, & prioritization.
5	CWE chains & composites Link(s) : cwe.mitre.org/data/reports/chains_and_composites.html Access / Cost : Free public	Relevance : Describes weakness chains & composite weaknesses. Notes & POIs : Important for modeling multi-step root causes & compound vulnerabilities.

Sl. #	Source Title	Notes
6	CWE schema docs Link(s) : cwe.mitre.org/documents/schema/index.html Access / Cost : Free public	Relevance : Schema documentation for CWE data. Notes & POIs : Use for parser validation & taxonomy consistency.
7	CWE data definitions	cwe.mitre.org/data/definitions/1000.html
8	CWE Top 25	cwe.mitre.org/top25
9	CWE AI/ML category - CWE-1448	cwe.mitre.org/data/definitions/1448.html
10	CWE AI Working Group	cwe.mitre.org/community/working_groups

7.2 CAPEC - attack patterns

Sl. #	Source Title	Notes
1	CAPEC home Link(s) : capec.mitre.org Access / Cost : Free public	Relevance : Catalog of attack patterns used to exploit weaknesses. Notes & POIs : CAPEC bridges weakness taxonomy & attacker behavior patterns.
2	CAPEC downloads Link(s) : capec.mitre.org/data/downloads.html Access / Cost : Free public downloads	Relevance : XML/CSV attack-pattern bundles. Notes & POIs : Prefer structured downloads for ingestion.
3	CAPEC schema docs Link(s) : capec.mitre.org/documents/schema/index.html Access / Cost : Free public	Relevance : Schema docs for CAPEC data. Notes & POIs : Important for parser validation.
4	CAPEC data index Link(s) : capec.mitre.org/data/index.html Access / Cost : Free public	Relevance : Browsable CAPEC entries & views. Notes & POIs : Useful for manual mapping & explanation.
5	MITRE CTI repository - ATT&CK & CAPEC in STIX Link(s) : github.com/mitre/cti Access / Cost : Free / open-source public GitHub repo	Relevance : MITRE ATT&CK & CAPEC datasets expressed in STIX 2.0. Notes & POIs : Useful for graph-based relationships. May differ from newer ATT&CK-specific STIX repo content.

7.3 MITRE ATT&CK

Sl. #	Source Title	Notes
1	ATT&CK Enterprise Matrix Link(s) : attack.mitre.org/matrices/enterprise Access / Cost : Free public	Relevance : Enterprise adversary tactics & techniques. Notes & POIs : More relevant for adversary behavior after exploitation than raw CVE severity.
2	ATT&CK Matrices Link(s) : attack.mitre.org/matrices Access / Cost : Free public	Relevance : ATT&CK matrices across domains. Notes & POIs : Useful for selecting enterprise, mobile, ICS, or other domain views.

Sl. #	Source Title	Notes
3	ATT&CK Data & Tools Link(s) : attack.mitre.org/resources/attack-data-and-tools Access / Cost : Free public	Relevance : ATT&CK Navigator, STIX/TAXII, Workbench, & tooling references. Notes & POIs : Prefer machine-readable STIX/TAXII for ingestion.
4	ATT&CK STIX data repo Link(s) : github.com/mitre-attack/attack-stix-data Access / Cost : Free / open-source public GitHub repo	Relevance : Machine-readable ATT&CK STIX data. Notes & POIs : Best source for automated technique/tactic ingestion.
5	MITRE CTI repository Link(s) : github.com/mitre/cti Access / Cost : Free / open-source public GitHub repo	Relevance : MITRE CTI STIX datasets. Notes & POIs : Keep for historical/related STIX content.
6	ATT&CK Navigator Link(s) : mitre-attack.github.io/attack-navigator Access / Cost : Free / open-source web tool	Relevance : Visual mapping of techniques to campaigns, risks, or controls. Notes & POIs : Useful for reporting & matrix visualization, not raw vuln ingestion.
7	ATT&CK Workbench Link(s) : github.com/center-for-threat-informed-defense/attack-workbench-frontend Access / Cost : Free / open-source public GitHub repo	Relevance : Tooling for ATT&CK customization & management. Notes & POIs : Useful for internal technique mapping workflows.
8	ATT&CK TAXII server docs Link(s) : attack.mitre.org/resources/attack-data-and-tools Access / Cost : Free public	Relevance : TAXII/STIX access docs. Notes & POIs : Same source as ATT&CK Data & Tools; retained to preserve the explicit TAXII reference.
9	ATT&CK Sync Link(s) : github.com/center-for-threat-informed-defense/attack-sync Access / Cost : Free / open-source public GitHub repo	Relevance : Tooling for consuming MITRE ATT&CK version updates into internal systems & processes. Notes & POIs : Useful for keeping local ATT&CK technique mappings current.
10	MITRE ATT&CK Python Link(s) : github.com/mitre-attack/mitreattack-python Access / Cost : Free / open-source public GitHub repo	Relevance : Python module for working with ATT&CK datasets. Notes & POIs : Useful for programmatic ATT&CK ingestion, transformation, & analysis.
11	ATT&CK Navigator GitHub repo Link(s) : github.com/mitre-attack/attack-navigator Access / Cost : Free / open-source public GitHub repo	Relevance : Source repository for the ATT&CK Navigator web app. Notes & POIs : Complements the hosted Navigator URL; useful for local customization & offline visualization workflows.

7.4 AI/ML-specific adversary frameworks

Sl. #	Source Title	Notes
1	MITRE ATLAS Link(s) : atlas.mitre.org	Relevance : Living knowledge base of adversary tactics & techniques against AI-enabled systems.

Sl. #	Source Title	Notes
	Access / Cost : Free public	Notes & POIs : More directly relevant to AI systems than ATT&CK Enterprise alone.
2	MITRE ATLAS matrix Link(s) : atlas.mitre.org/matrices/ATLAS Access / Cost : Free public	Relevance : Matrix view of AI adversary tactics & techniques. Notes & POIs : Useful for AI threat modeling & impact mapping.
3	MITRE ATLAS techniques Link(s) : atlas.mitre.org/techniques Access / Cost : Free public	Relevance : Technique-level ATLAS entries. Notes & POIs : Use for structured AI attack technique mapping.
4	MITRE ATLAS case studies Link(s) : atlas.mitre.org/studies Access / Cost : Free public	Relevance : Case studies of AI attacks & failures. Notes & POIs : Helpful for real-world analogs & model training examples.
5	MITRE ATLAS data repository / case-study data Link(s) : github.com/mitre-atlas/atlas-data , case studies Access / Cost : Free / open-source public GitHub repo	Relevance : Structured ATLAS data, including case-study material. Notes & POIs : Prefer this for machine-readable ATLAS case-study ingestion.
6	MITRE ATLAS GitHub / Adversarial ML Threat Matrix Link(s) : github.com/mitre/advmthreatmatrix Access / Cost : Free / open-source public GitHub repo	Relevance : Historical & structured project data for adversarial ML threat matrix. Notes & POIs : May not be the most current ATLAS view; keep for lineage.
7	MITRE SAFE-AI report Link(s) : atlas.mitre.org/pdf-files/SAFEAI_Full_Report.pdf Access / Cost : Free public PDF	Relevance : AI system risk mapping across model, data, platform, & environment layers. Notes & POIs : Useful for AI-specific control mapping & architecture risk analysis.
8	OWASP Top 10 for LLM Applications Link(s) : owasp.org/www-project-top-10-for-large-language-model-applications Access / Cost : Free / open-source community project	Relevance : Practical LLM application vulnerability taxonomy. Notes & POIs : Useful for AI appsec detection categories beyond CVE.
9	OWASP Top 10 for Machine Learning Security Link(s) : owasp.org/www-project-machine-learning-security-top-10 Access / Cost : Free / open-source community project	Relevance : ML-specific application/security risk taxonomy. Notes & POIs : Complements ATLAS with appsec-oriented framing.
10	OWASP AI Exchange Link(s) : owaspai.org Access / Cost : Free public community resource	Relevance : AI security risks, controls, & threat modeling references. Notes & POIs : Useful for governance & risk mapping.
11	NIST AI Risk Management Framework Link(s) : www.nist.gov/itl/ai-risk-management-framework	Relevance : AI risk management framework.

Sl. #	Source Title	Notes
	Access / Cost : Free public	Notes & POIs : Useful for risk controls, governance, & impact framing.
12	NIST AI RMF 1.0 PDF Link(s) : nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf Access / Cost : Free public PDF	Relevance : AI RMF 1.0 document. Notes & POIs : PDF reference; not a vulnerability feed.
13	NIST AI 600-1 - Generative AI Profile Link(s) : www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence Access / Cost : Free public	Relevance : GenAI risk profile companion to AI RMF. Notes & POIs : Useful for LLM/generative AI-specific risk categories.
14	NIST adversarial machine learning taxonomy Link(s) : www.nist.gov/publications/adversarial-machine-learning-taxonomy-and-terminology-attacks-and-mitigations Access / Cost : Free public	Relevance : Taxonomy & terminology for adversarial ML attacks & mitigations. Notes & POIs : Good for consistent AI vulnerability vocabulary.
15	MLCommons AI Safety Link(s) : mlcommons.org/working-groups/ai-safety Access / Cost : Free public community resource	Relevance : AI safety benchmarks & working group context. Notes & POIs : Useful for AI system risk evaluation, not direct CVE matching.
16	MITRE ATLAS AI Risk Database Link(s) : github.com/mitre-atlas/ai-risk-database Access / Cost : Free / open-source public GitHub repo	Relevance : AI supply-chain risk database associated with MITRE ATLAS ecosystem work. Notes & POIs : Useful for AI-specific supply-chain risk analysis & case-study style enrichment.
17	Cisco AI Defense Skill Scanner Link(s) : github.com/cisco-ai-defense/skill-scanner Access / Cost : Free / open-source public GitHub repo	Relevance : Security scanner for agent skills. Notes & POIs : Useful for AI-agent/tooling security review, prompt/tool-surface assessment, & skill-level exposure analysis.

[Back to Index](#)

D. Affectedness Truth: Package, OS, Vendor, Cloud, ICS & Product Advisories

8. Open-source vulnerability databases & package advisory sources

8.1 OSV ecosystem

Sl. #	Source Title	Notes
1	OSV main site Link(s) : osv.dev Access / Cost : Free public / open data	Relevance : Aggregates OSS vulnerabilities by package ecosystem, version, commit, & aliases. Key for dependency-based detection. Notes & POIs : OSV is package/version- centric & often

Sl. #	Source Title	Notes
		better than CPE for OSS packages. Coverage depends on upstream ecosystem feeds.
2	OSV vulnerability list Link(s) : osv.dev/list Access / Cost : Free public	Relevance : Human-browsable OSV records. Notes & POIs : Useful for manual triage & ecosystem browsing. Prefer API/full downloads for automation.
3	OSV full database download Link(s) : google.github.io/osv.dev/data/#full-database-download Access / Cost : Free public / open data	Relevance : Full database ZIP, including withdrawn records, via <code>gs://osv-vulnerabilities/all.zip</code> . Notes & POIs : Best for local mirroring. Preserve withdrawn records for historical auditability.
4	OSV data sources page Link(s) : google.github.io/osv.dev/data Access / Cost : Free public	Relevance : Per-ecosystem downloads & full-database download. Notes & POIs : Useful for targeted ecosystem ingestion.
5	OSV schema rendered spec	osv.dev/schema
6	OSV schema GitHub repo	github.com/google/osv-schema
7	OSV API docs	google.github.io/osv.dev/post-v1-query
8	OSV Scanner	google.github.io/osv-scanner
9	OSV Scanner GitHub	github.com/google/osv-scanner
10	OSV ecosystem list	osv.dev/list
11	OSV.dev GitHub repository	github.com/google/osv.dev

8.2 GitHub Advisory Database

Sl. #	Source Title	Notes
1	GitHub Advisory Database - web Link(s) : github.com/advisories Access / Cost : Free public	Relevance : GitHub-reviewed, unreviewed, malware, GHSA, & CVE advisory records across ecosystems. Notes & POIs : GHSA records can exist without CVEs. Preserve alias relationships between GHSA, CVE, & OSV.
2	GitHub Advisory Database repo Link(s) : github.com/github/advisory-database Access / Cost : Free / open-source public GitHub repo	Relevance : Raw advisory data for local ingestion. Notes & POIs : Use for mirroring; validate ecosystem/version range semantics.
3	About GitHub Advisory Database Link(s) : docs.github.com/en/code-security/concepts/vulnerability-reporting-and-management/about-the-github-advisory-database Access / Cost : Free public docs	Relevance : Explains reviewed, unreviewed, & malware advisory model. Notes & POIs : Important for confidence scoring. Reviewed vs unreviewed status affects dependability.

Sl. #	Source Title	Notes
4	GitHub Security Advisory GraphQL object Link(s) : docs.github.com/en/graphql/reference/objects#securityadvisory Access / Cost : Free docs; API usage may require GitHub auth token	Relevance : Programmatic advisory metadata access via GraphQL. Notes & POIs : Useful for complex filtered queries. Requires API authentication for robust use.
5	GitHub REST API - global security advisories Link(s) : docs.github.com/en/rest/security-advisories/global-advisories Access / Cost : Free public API; auth recommended for higher rate limits	Relevance : REST access for listing & retrieving global security advisories. Notes & POIs : Easier to integrate than GraphQL for many ingestion jobs.
6	GitHub REST API - security advisories root Link(s) : docs.github.com/en/rest/security-advisories Access / Cost : Free public docs; some repository endpoints require permissions	Relevance : Root documentation for global & repository security advisory endpoints. Notes & POIs : Use to distinguish global advisories from repo-private advisories.
7	GitHub Dependabot alerts REST API Link(s) : docs.github.com/en/rest/dependabot/alerts Access / Cost : Requires GitHub account, repository access, & relevant permissions	Relevance : Repository-specific vulnerability exposure from dependency graph. Notes & POIs : Requires repo access. Useful for actual asset exposure, not just global vulnerability existence.
8	Dependabot supported ecosystems Link(s) : docs.github.com/en/code-security/reference/supply-chain-security/supported-ecosystems-and-repositories Access / Cost : Free public docs	Relevance : Supported ecosystem list for GitHub dependency graph & alerts. Notes & POIs : Coverage constraints impact blind spots in detection.
9	GitHub malware advisories	github.com/advisories?query=type%3Amalware
10	GitHub npm advisories	github.com/advisories?query=ecosystem%3Anpm
11	GitHub pip advisories	github.com/advisories?query=ecosystem%3Apip
12	GitHub Maven advisories	github.com/advisories?query=ecosystem%3Amaven
13	GitHub NuGet advisories	github.com/advisories?query=ecosystem%3Anuget
14	GitHub Go advisories	github.com/advisories?query=ecosystem%3Ago
15	GitHub RubyGems advisories	github.com/advisories?query=ecosystem%3Arubygems
16	GitHub Rust advisories	github.com/advisories?query=ecosystem%3Arust
17	GitHub Composer advisories	github.com/advisories?query=ecosystem%3Acomposer

Sl. #	Source Title	Notes
18	GitHub Pub advisories	github.com/advisories?query=ecosystem%3Apub
19	GitHub Swift advisories	github.com/advisories?query=ecosystem%3Aswift
20	GitHub Erlang advisories	github.com/advisories?query=ecosystem%3Aerlang

8.3 Language & package ecosystem advisory databases

8.3.1 Go

Sl. #	Source Title	Notes
1	Go Vulnerability Database Link(s) : vuln.go.dev Access / Cost : Free public / open data	Relevance : Official Go vulnerability database for Go modules. Notes & POIs : Strong source for Go-specific affected symbols, modules, packages, & fixed versions.
2	Go vulnerability database docs Link(s) : go.dev/doc/security/vuln/database Access / Cost : Free public docs	Relevance : Explains Go vulnerability DB data model & OSV usage. Notes & POIs : Important for correct ingestion & symbol/package-level interpretation.
3	Go vuln browser Link(s) : pkg.go.dev/vuln Access / Cost : Free public	Relevance : Human-readable curated Go vulnerability reports. Notes & POIs : Useful for triage & manual review.
4	Go vuln tooling Link(s) : pkg.go.dev/golang.org/x/vuln/cmd/govulncheck Access / Cost : Free / open-source Go module	Relevance : Go source/binary vulnerability checking. Notes & POIs : Can reduce false positives by analyzing call reachability in Go code.

8.3.2 Rust

Sl. #	Source Title	Notes
1	RustSec Link(s) : rustsec.org Access / Cost : Free public / open-source ecosystem	Relevance : Rust crate advisory ecosystem. Notes & POIs : Often includes Rust-specific unsoundness, yanked crates, & ecosystem-specific risk.
2	RustSec advisory DB repo Link(s) : github.com/RustSec/advisory-db Access / Cost : Free / open-source public GitHub repo	Relevance : Machine-ingestible Rust advisories. Notes & POIs : Good for local ingestion & cargo-audit compatible workflows.
3	RustSec advisories browser Link(s) : rustsec.org/advisories Access / Cost : Free public	Relevance : Human-browsable Rust advisories. Notes & POIs : Useful for manual triage.
4	cargo-audit Link(s) : github.com/RustSec/rustsec/tree/main/cargo-	Relevance : RustSec-based vulnerability scanner.

Sl. #	Source Title	Notes
	audit Access / Cost : Free / open-source public GitHub repo	Notes & POIs : Reference implementation for Rust dependency scanning.

8.3.3 Python / PyPI

Sl. #	Source Title	Notes
1	PyPA advisory database Link(s) : github.com/pypa/advisory-database Access / Cost : Free / open-source public GitHub repo	Relevance : Python/PyPI advisory source. Notes & POIs : Use with OSV & GitHub advisories for better Python coverage.
2	PyPI security page Link(s) : pypi.org/security Access / Cost : Free public	Relevance : PyPI security reporting & advisory context. Notes & POIs : Useful for process context, not necessarily complete advisory ingestion.
3	pip-audit Link(s) : github.com/pypa/pip-audit Access / Cost : Free / open-source public GitHub repo	Relevance : Python dependency vulnerability scanner. Notes & POIs : Reference implementation for Python dependency assessment.
4	Safety DB Link(s) : github.com/pyupio/safety-db Access / Cost : Free public GitHub repo; related products may be commercial	Relevance : Historical Python advisory source. Notes & POIs : Validate freshness & licensing before relying on it.

8.3.4 JavaScript / npm

Sl. #	Source Title	Notes
1	npm advisories via GitHub Link(s) : github.com/advisories?query=ecosystem%3Anpm Access / Cost : Free public	Relevance : npm ecosystem vulnerability advisories. Notes & POIs : Semver ranges, lockfiles, transitive dependencies, & malicious packages require careful parsing.
2	Node.js Security Working Group Link(s) : github.com/nodejs/security-wg Access / Cost : Free / open-source public GitHub repo	Relevance : Node ecosystem security coordination & historical advisory sources. Notes & POIs : Some historical records may be superseded by GitHub Advisory DB.
3	npm audit docs Link(s) : docs.npmjs.com/cli/commands/npm-audit Access / Cost : Free public docs	Relevance : Documents npm audit behavior. Notes & POIs : Useful to understand scanner behavior, dependency tree handling, & remediation suggestions.
4	Socket.dev security research Link(s) : socket.dev/blog Access / Cost : Free public blog; product/API features may be commercial	Relevance : Malicious package & JS supply-chain threat intel. Notes & POIs : Research source. Validate indicators & package claims against primary registries.

8.3.5 Java / Maven / JVM

Sl. #	Source Title	Notes
1	Sonatype OSS Index Link(s) : ossindex.sonatype.org Access / Cost : Free tier / API terms; Sonatype products may be commercial	Relevance : OSS vulnerability intelligence commonly used for Maven & other ecosystems. Notes & POIs : Commercial/community source. Validate API terms, limits, & provenance.
2	Sonatype vulnerability database Link(s) : sonatype.com/resources/vulnerability-database Access / Cost : Free public search / commercial ecosystem	Relevance : Sonatype vulnerability intelligence database. Notes & POIs : Useful for enrichment & triage, but not canonical.
3	Maven Central Link(s) : central.sonatype.com Access / Cost : Free public	Relevance : Package identity & metadata for JVM packages. Notes & POIs : Not a vulnerability DB, but essential for coordinate resolution & metadata.
4	OSS Index API docs Link(s) : ossindex.sonatype.org/doc/rest Access / Cost : Free tier / API terms	Relevance : REST API access for OSS Index. Notes & POIs : Consider rate limits, authentication, & terms before ingestion.

8.3.6 PHP / Composer

Sl. #	Source Title	Notes
1	FriendsOfPHP security advisories Link(s) : github.com/FriendsOfPHP/security-advisories Access / Cost : Free / open-source public GitHub repo	Relevance : PHP Composer package advisories. Notes & POIs : Historical & ecosystem-specific source. Cross-check with Packagist & GHSA.
2	Packagist security advisories API Link(s) : packagist.org/apidoc#list-security-advisories Access / Cost : Free public API docs / public API	Relevance : Composer package advisory API. Notes & POIs : Direct ecosystem source for Composer package advisories.
3	Composer audit docs Link(s) : getcomposer.org/doc/03-cli.md#audit Access / Cost : Free public docs	Relevance : Documents Composer audit behavior. Notes & POIs : Useful for implementation parity with Composer-native workflows.

8.3.7 Ruby

Sl. #	Source Title	Notes
1	RubySec advisory DB Link(s) : github.com/rubysec/ruby-advisory-db Access / Cost : Free / open-source public GitHub repo	Relevance : RubyGems advisories. Notes & POIs : Cross-check with GHSA RubyGems advisories.

Sl. #	Source Title	Notes
2	Bundler audit Link(s) : github.com/rubysec/bundler-audit Access / Cost : Free / open-source public GitHub repo	Relevance : Ruby dependency vulnerability scanner. Notes & POIs : Reference implementation for Gemfile.lock scanning.

8.3.8 .NET / NuGet

Sl. #	Source Title	Notes
1	NuGet advisories via GitHub Link(s) : github.com/advisories?query=ecosystem%3Anuget Access / Cost : Free public	Relevance : NuGet ecosystem advisories. Notes & POIs : Use with lockfile/project metadata for actual exposure.
2	NuGet audit docs Link(s) : learn.microsoft.com/en-us/nuget/concepts/auditing-packages Access / Cost : Free public docs	Relevance : Documents NuGet package auditing. Notes & POIs : Useful for Microsoft ecosystem parity & remediation guidance.

8.3.9 Erlang / Elixir / Hex

Sl. #	Source Title	Notes
1	Erlang advisories via GitHub Link(s) : github.com/advisories?query=ecosystem%3Aerlang Access / Cost : Free public	Relevance : Erlang/Hex advisories. Notes & POIs : Validate ecosystem naming, package coordinates, & version semantics.
2	Hex package manager Link(s) : hex.pm Access / Cost : Free public	Relevance : Package registry for Erlang/Elixir packages. Notes & POIs : Registry metadata helps resolve package identity.

8.3.10 Dart / Flutter / Pub

Sl. #	Source Title	Notes
1	Pub advisories via GitHub Link(s) : github.com/advisories?query=ecosystem%3Apub Access / Cost : Free public	Relevance : Dart/Pub advisories. Notes & POIs : Coverage depends on GitHub advisory ingestion.
2	Dart package repository Link(s) : pub.dev Access / Cost : Free public	Relevance : Package registry for Dart/Flutter dependencies. Notes & POIs : Useful for package identity & version metadata.

8.3.11 Swift

Sl. #	Source Title	Notes
1	Swift advisories via GitHub Link(s) : github.com/advisories?query=ecosystem%3Aswift Access / Cost : Free public	Relevance : Swift ecosystem advisories. Notes & POIs : Coverage depends on GitHub Advisory DB support.
2	Swift Package Index Link(s) : swiftpackageindex.com Access / Cost : Free public	Relevance : Swift package metadata & ecosystem context. Notes & POIs : Not a vulnerability DB, but useful for package discovery & metadata.

[Back to Index](#)

9. Vendor, OS, distribution, container & package affectedness feeds

9.1 Scanner-oriented aggregators & vulnerability DB builders

Sl. #	Source Title	Notes
1	NeuVector vul-dbgen Link(s) : github.com/neuvector/vul-dbgen Access / Cost : Free / open-source public GitHub repo	Relevance : Vulnerability DB generation source originally flagged by this project. Notes & POIs : Useful as a reference for aggregating distro/package vulnerability feeds.
2	NeuVector vul-source Link(s) : github.com/neuvector/vul-source Access / Cost : Free / open-source public GitHub repo	Relevance : Vulnerability source data used by NeuVector workflows. Notes & POIs : Review for source coverage & feed normalization logic.
3	Aqua Trivy vulnerability docs Link(s) : trivy.dev/docs/latest/scanner/vulnerability Access / Cost : Free public docs	Relevance : Scanner behavior across OS packages, language packages, misconfig, Kubernetes, etc. Notes & POIs : Useful for scanner semantics & supported target types.
4	Trivy DB Link(s) : github.com/aquasecurity/trivy-db Access / Cost : Free / open-source public GitHub repo	Relevance : Converts raw advisories into Trivy DB format. Notes & POIs : Useful for ingestion architecture & feed normalization patterns.
5	Trivy Java DB Link(s) : github.com/aquasecurity/trivy-java-db Access / Cost : Free / open-source public GitHub repo	Relevance : Java-specific vulnerability database used by Trivy. Notes & POIs : Useful for Maven/JAR matching.

Sl. #	Source Title	Notes
6	Trivy database configuration docs Link(s) : trivy.dev/docs/latest/configuration/db Access / Cost : Free public docs	Relevance : Documents Trivy DB artifacts & configuration. Notes & POIs : Useful for operational scanner deployment.
7	Anchore Grype Link(s) : github.com/anchore/grype Access / Cost : Free / open-source public GitHub repo	Relevance : Vulnerability scanner for container images & filesystems. Notes & POIs : Useful reference for SBOM-to-vuln matching.
8	Anchore Grype DB Link(s) : github.com/anchore/grype-db Access / Cost : Free / open-source public GitHub repo	Relevance : Builds Grype vulnerability database from upstream sources. Notes & POIs : Useful for feed normalization & source coverage comparison.
9	Anchore Syft Link(s) : github.com/anchore/syft Access / Cost : Free / open-source public GitHub repo	Relevance : SBOM generation for scanning & exposure matching. Notes & POIs : Pair with Grype for inventory-to-vulnerability workflow.
10	Quay ClairCore Link(s) : github.com/quay/claircore Access / Cost : Free / open-source public GitHub repo	Relevance : Clair vulnerability matching engine core. Notes & POIs : Useful for container security ingestion patterns.
11	Clair Link(s) : github.com/quay/clair Access / Cost : Free / open-source public GitHub repo	Relevance : Container vulnerability scanner. Notes & POIs : Compare feed matching behavior with Trivy & Grype.
12	VulnerableCode Link(s) : github.com/nexB/vulnerablecode Access / Cost : Free / open-source public GitHub repo	Relevance : Open vulnerability DB aggregator. Notes & POIs : Useful for importer coverage & open-source ingestion architecture.
13	VulnerableCode importer docs Link(s) : vulnerablecode.readthedocs.io/en/latest/importers_link.html Access / Cost : Free public docs	Relevance : Lists supported importer sources. Notes & POIs : Good checklist for source coverage.
14	Dependency-Track Link(s) : dependencytrack.org Access / Cost : Free / open-source core project	Relevance : SBOM-oriented vulnerability management platform. Notes & POIs : Useful reference for BOM ingestion & component risk tracking.
15	Dependency-Track data sources Link(s) : docs.dependencytrack.org/datasources/overview	Relevance : Documents Dependency-Track data sources.

Sl. #	Source Title	Notes
	Access / Cost : Free public docs	Notes & POIs : Useful for comparing source prioritization.
16	Dependency-Track GitHub Advisories datasource Link(s) : docs.dependencytrack.org/datasources/github-advisories Access / Cost : Free public docs	Relevance : Mirrors GHSA via GitHub public GraphQL API. Notes & POIs : Useful reference for GHSA ingestion.
17	OpenVAS / Greenbone Community Feed Link(s) : www.greenbone.net/en/community-feed Access / Cost : Free community feed; commercial Greenbone feeds/products available	Relevance : Network vulnerability test feed. Notes & POIs : Useful for host/network exposure detection, not package-only matching.
18	Wazuh vulnerability detector Link(s) : documentation.wazuh.com/current/user-manual/capabilities/vulnerability-detection/index.html Access / Cost : Free public docs; Wazuh open-source, commercial support available	Relevance : Endpoint vulnerability detection capability. Notes & POIs : Useful for host-level package inventory & vuln matching behavior.
19	OSV-SCALIBR Link(s) : github.com/google/osv-scalibr Access / Cost : Free / open-source public GitHub repo	Relevance : Google library for Software Composition Analysis. Notes & POIs : Useful for SCA implementation patterns, package/component extraction, vulnerability matching, & OSV-aligned workflows.
20	HarborGuard Link(s) : github.com/HarborGuard/HarborGuard Access / Cost : Free / open-source public GitHub repo	Relevance : Image vulnerability scanning & patching platform with multi-tool integration. Notes & POIs : Relevant to container/image vulnerability management, scanner orchestration, & remediation workflow automation.

9.2 Red Hat / RHEL / CentOS Stream

Sl. #	Source Title	Notes
---	---	---
-- -;	Link(s) : --- Access / Cost : ---	Relevance : --- Notes & POIs : ---
1	Red Hat Security Data Link(s) : access.redhat.com/security/data Access / Cost : Free public data; some product details/support content may require subscription	Relevance : Red Hat CSAF/VEX, OSV, OVAL, CVE data. Notes & POIs : Essential for RHEL affectedness & backport-aware status.
2	Red Hat Security Data API	Relevance : API retrieves Red Hat

Sl. #	Source Title	Notes
	Link(s) : docs.redhat.com/en/documentation/red_hat_security_data_api/1.0/html-single/red_hat_security_data_api/index Access / Cost : Free public docs/API; support content may require subscription	CVE/advisory/security data. Notes & POIs : Prefer API for automation; handle auth/rate constraints if applicable.
3	Red Hat CVE database Link(s) : access.redhat.com/security/security-updates/#/cve Access / Cost : Free public	Relevance : Red Hat CVE lookup. Notes & POIs : Human-facing; use data APIs for automation.
4	Red Hat OVAL data Link(s) : www.redhat.com/security/data/oval Access / Cost : Free public	Relevance : OVAL definitions for vulnerability assessment. Notes & POIs : Useful for scanner compatibility & package-state evaluation.
5	Red Hat CSAF/VEX guidance Link(s) : redhatproductsecurity.github.io/security-data-guidelines/csaf-vex Access / Cost : Free public docs	Relevance : Explains Red Hat CSAF/VEX & product/package semantics. Notes & POIs : Important for correct interpretation of affected/not-affected states.
6	Red Hat security advisories Link(s) : access.redhat.com/security/security-updates/#/security-advisories Access / Cost : Free public listing; some advisory/product support details may require subscription	Relevance : Red Hat advisory listing. Notes & POIs : Useful for patch/remediation references.
7	CentOS Stream security tracker Link(s) : gitlab.com/redhat/centos-stream/rpms Access / Cost : Free public GitLab	Relevance : CentOS Stream package source context. Notes & POIs : Use carefully; package repo state differs from security advisory truth.

9.3 Debian

Sl. #	Source Title	Notes
1	Debian Security Tracker Link(s) : security-tracker.debian.org Access / Cost : Free public	Relevance : Debian-specific package vulnerability status. Notes & POIs : Essential for Debian affectedness & backported patches.

Sl. #	Source Title	Notes
2	Debian Security Tracker JSON Link(s) : security-tracker.debian.org/tracker/data/json Access / Cost : Free public JSON	Relevance : Machine-readable Debian vulnerability data. Notes & POIs : Primary automation source for Debian.
3	Debian Security Tracker source Git Link(s) : salsa.debian.org/security-tracker-team/security-tracker Access / Cost : Free / open-source public Git repo	Relevance : Source repo for tracker data. Notes & POIs : Useful for diffs, auditing, & local mirroring.
4	Debian Security Information Link(s) : www.debian.org/security Access / Cost : Free public	Relevance : Debian security notices & process context. Notes & POIs : Useful for advisory references & manual review.
5	Debian Security Tracker docs Link(s) : security-team.debian.org/security_tracker.html Access / Cost : Free public docs	Relevance : Explains Debian tracker semantics. Notes & POIs : Important for interpreting statuses like fixed, vulnerable, ignored, or postponed.
6	Debian OVAL Link(s) : www.debian.org/security/oval Access / Cost : Free public	Relevance : OVAL data for Debian vulnerability assessment. Notes & POIs : Useful for scanner integrations.

9.4 Ubuntu / Canonical

Sl. #	Source Title	Notes
1	Ubuntu Security Notices Link(s) : ubuntu.com/security/notices Access / Cost : Free public	Relevance : Ubuntu security notices for fixed packages. Notes & POIs : Useful for patch references & release-specific remediation.
2	Ubuntu CVE reports Link(s) : ubuntu.com/security/cves Access / Cost : Free public	Relevance : Ubuntu CVE tracking by package/release. Notes & POIs : Important for Ubuntu affectedness & backport interpretation.
3	Ubuntu OVAL Link(s) : ubuntu.com/security/oval Access / Cost : Free public	Relevance : OVAL data for vulnerability assessment & patch status. Notes & POIs : Useful for scanner compatibility.
4	Ubuntu VEX data Link(s) : ubuntu.com/security/vex Access / Cost : Free public	Relevance : Ubuntu VEX data. Notes & POIs : Useful for affected/not-affected status & scanner false-positive reduction.

Sl. #	Source Title	Notes
5	Ubuntu VEX docs Link(s) : documentation.ubuntu.com/security/security-updates/vex Access / Cost : Free public docs	Relevance : Ubuntu VEX source documentation. Notes & POIs : Important for interpreting Canonical VEX publication model.
6	Ubuntu Security Notices GitHub Link(s) : github.com/canonical/ubuntu-security-notices Access / Cost : Free public GitHub repo	Relevance : USN/LSN JSON, OSV JSON, & OpenVEX JSON formats. Notes & POIs : Strong automation source. Preserve format-specific semantics.
7	Ubuntu Security Tracker Git Link(s) : git.launchpad.net/ubuntu-cve-tracker Access / Cost : Free public Git repo	Relevance : Ubuntu CVE tracker source. Notes & POIs : Useful for local mirroring & historical diffing.
8	Ubuntu security updates docs Link(s) : documentation.ubuntu.com/security/security-updates Access / Cost : Free public docs	Relevance : Ubuntu security update documentation. Notes & POIs : Useful for process context & VEX/OVAL interpretation.

9.5 Alpine

Sl. #	Source Title	Notes
1	Alpine SecDB Link(s) : secdb.alpinelinux.org Access / Cost : Free public	Relevance : Current Alpine machine-readable security DB. Notes & POIs : Primary Alpine ingestion source.
2	Alpine Security Tracker Link(s) : security.alpinelinux.org Access / Cost : Free public	Relevance : Tracks Alpine security issues. Notes & POIs : Useful for human review & status context.
3	Alpine SecDB deprecated GitHub mirror Link(s) : github.com/alpinelinux/alpine-secdb Access / Cost : Free public GitHub repo; deprecated	Relevance : Historical Alpine SecDB mirror. Notes & POIs : Deprecated; do not rely on it for current ingestion.
4	Alpine packages Link(s) : pkgs.alpinelinux.org/packages Access / Cost : Free public	Relevance : Alpine package metadata. Notes & POIs : Not a vulnerability DB, but helps resolve package names & versions.

9.6 SUSE / openSUSE

Sl. #	Source Title	Notes
1	SUSE CSAF Link(s) : www.suse.com/support/security/csaf Access / Cost : Free public	Relevance : SUSE CSAF advisory data. Notes & POIs : Good for vendor-asserted affectedness & remediation states.
2	SUSE CVRF / OVAL security data Link(s) : www.suse.com/support/security/oval Access / Cost : Free public	Relevance : SUSE OVAL/CVRF security data. Notes & POIs : Useful for scanner compatibility & package-state evaluation.
3	SUSE CVE pages Link(s) : www.suse.com/security/cve Access / Cost : Free public	Relevance : SUSE CVE lookup. Notes & POIs : Human-facing; use machine-readable feeds when available.
4	SUSE Security Advisories Link(s) : www.suse.com/support/update/announcement Access / Cost : Free public	Relevance : SUSE security advisory listing. Notes & POIs : Useful for remediation & patch references.
5	openSUSE Security Announce Link(s) : lists.opensuse.org/archives/list/security-announce@lists.opensuse.org Access / Cost : Free public	Relevance : openSUSE security announcement mailing list archive. Notes & POIs : Useful for distro-specific disclosure context.

9.7 Oracle Linux

Sl. #	Source Title	Notes
1	Oracle Security Alerts & Critical Patch Updates Link(s) : www.oracle.com/security-alerts Access / Cost : Free public	Relevance : Oracle CPU, Security Alerts, third-party bulletins, & CVE mappings. Notes & POIs : Oracle products often require vendor advisory interpretation beyond NVD.
2	Oracle Linux security data Link(s) : linux.oracle.com/security Access / Cost : Free public	Relevance : Oracle Linux security data. Notes & POIs : Useful for Oracle Linux affectedness.
3	Oracle Linux OVAL Link(s) : linux.oracle.com/security/oval Access / Cost : Free public	Relevance : Oracle Linux OVAL definitions. Notes & POIs : Useful for scanner compatibility.

| 4 | Oracle Linux errata | linux.oracle.com/errata | Free public | Oracle Linux errata. | Use for patch mapping & fixed versions. | | 5 | Oracle Linux CVE search | linux.oracle.com/cve | Free public | Oracle Linux CVE lookup. | Human lookup source; pair with OVAL/errata for automation. |

9.8 Amazon Linux

Sl. #	Source Title	Notes
1	Amazon Linux Security Center Link(s) : alas.aws.amazon.com Access / Cost : Free public	Relevance : Amazon Linux security advisory portal. Notes & POIs : Important for Amazon Linux package affectedness.
2	Amazon Linux ALAS Explorer Link(s) : explore.alas.aws.amazon.com Access / Cost : Free public	Relevance : Search/explore interface for Amazon Linux advisories. Notes & POIs : Useful for manual triage & ALAS advisory lookup.
3	Amazon Linux 2 advisories Link(s) : alas.aws.amazon.com/alas2.html Access / Cost : Free public	Relevance : Amazon Linux 2 advisories. Notes & POIs : Version-specific advisory stream.
4	Amazon Linux 2023 advisories Link(s) : alas.aws.amazon.com/AL2023 Access / Cost : Free public	Relevance : Amazon Linux 2023 advisories. Notes & POIs : Keep AL2 & AL2023 separate because package baselines differ.
5	AWS Security Bulletins Link(s) : aws.amazon.com/security/security-bulletins Access / Cost : Free public	Relevance : AWS security bulletins for services & platforms. Notes & POIs : Cloud-service affectedness may not map cleanly to package versions.
6	Amazon Linux 2023 GitHub repository Link(s) : github.com/amazonlinux/amazon-linux-2023 Access / Cost : Free public GitHub repo	Relevance : Amazon Linux 2023 project repository. Notes & POIs : Useful for Amazon Linux 2023 package context, release notes, source/package metadata references, & distro-specific affectedness workflows.

9.9 Fedora, AlmaLinux, Rocky, Arch, Gentoo

Sl. #	Source Title	Notes
1	Fedora security updates Link(s) : bodhi.fedoraproject.org/updates/?type=security Access / Cost : Free public	Relevance : Fedora security update advisories. Notes & POIs : Useful for Fedora package remediation tracking.
2	Fedora packages Link(s) : packages.fedoraproject.org Access / Cost : Free public	Relevance : Fedora package metadata. Notes & POIs : Not a vulnerability DB, but useful for package identity & version resolution.
3	Fedora packages static - Pagure Link(s) : pagure.io/fedora-packages-static Access / Cost : Free public Pagure project; manually revalidate	Relevance : Fedora package-name & metadata/script reference. Notes & POIs : Keep in link-check allowlist until manually validated; not a primary security advisory source.

Sl. #	Source Title	Notes
4	AlmaLinux Errata Link(s) : errata.almalinux.org Access / Cost : Free public	Relevance : AlmaLinux errata & security advisories. Notes & POIs : Useful for RHEL-compatible distro assessment.
5	AlmaLinux OSV data Link(s) : github.com/AlmaLinux/osv-database Access / Cost : Free public GitHub repo	Relevance : AlmaLinux OSV-formatted data. Notes & POIs : Good for OSV-based pipelines.
6	Rocky Linux security advisories Link(s) : errata.build.resf.org Access / Cost : Free public	Relevance : Rocky Linux errata/security advisories. Notes & POIs : Useful for RHEL-compatible distro assessment.
7	Arch Linux Security Tracker Link(s) : security.archlinux.org Access / Cost : Free public	Relevance : Arch Linux security tracker. Notes & POIs : Rolling-release semantics differ from fixed-release distros.
8	Arch Linux security JSON Link(s) : security.archlinux.org/json Access / Cost : Free public JSON	Relevance : Machine-readable Arch security data. Notes & POIs : Useful for automation.
9	Gentoo GLSA Link(s) : security.gentoo.org/glsa Access / Cost : Free public	Relevance : Gentoo Linux Security Advisories. Notes & POIs : Useful for Gentoo package affectedness.
10	Gentoo GLSA XML Link(s) : security.gentoo.org/glsa/feed.rss Access / Cost : Free public RSS/XML	Relevance : Gentoo GLSA RSS/XML feed. Notes & POIs : Useful for feed-based monitoring.

9.10 Wolfi / Chainguard

Sl. #	Source Title	Notes
1	Wolfi OS advisories Link(s) : github.com/wolfi-dev/advisories Access / Cost : Free public GitHub repo	Relevance : Wolfi OS advisory data. Notes & POIs : Important for modern minimal container images.
2	Wolfi SecDB generator Link(s) : github.com/wolfi-dev/secdb Access / Cost : Free / open-source public GitHub repo	Relevance : Generates Wolfi security DBs based on Alpine secdb format. Notes & POIs : Useful for understanding feed generation semantics.
3	Wolfi OS feed Link(s) : packages.wolfi.dev/os/security.json Access / Cost : Free public feed	Relevance : Wolfi package security feed. Notes & POIs : Use this for Wolfi base images.
4	Chainguard Enterprise feed	Relevance : Chainguard Enterprise package security feed.

Sl. #	Source Title	Notes
	Link(s) : packages.cgr.dev/chainguard/security.json Access / Cost : Publicly reachable feed; may relate to commercial Chainguard product scope	Notes & POIs : Separate from Wolfi OS feed. Confirm entitlement/licensing before commercial redistribution.
5	Chainguard security advisories docs	edu.chainguard.dev/chainguard/chainguard-images/staying-secure/security-advisories/how-chainguard-issues
6	Wolfi vulnerabilities in OSV	osv.dev/list?ecosystem=Wolfi
7	Chainguard OSV advisory feed context	www.chainguard.dev/unchained/chainguard-enhances-security-with-osv-advisory-feed

[Back to Index](#)

10. Vendor advisories for enterprise impact assessment

10.1 Major OS, browser & platform vendors

Sl. #	Source Title	Notes
1	Microsoft Security Update Guide Link(s) : msrc.microsoft.com/update-guide Access / Cost : Free public	Relevance : Microsoft vulnerability advisories, CVEs, affected products, & fixes. Notes & POIs : Critical for Windows, Office, Exchange, Azure components, & enterprise Microsoft stack.
2	Microsoft MSRC blog Link(s) : msrc.microsoft.com/blog Access / Cost : Free public	Relevance : Microsoft security research & advisory context. Notes & POIs : Useful for exploitation context & urgent guidance.
3	Microsoft Security Response Center Link(s) : msrc.microsoft.com Access / Cost : Free public	Relevance : Microsoft security response portal. Notes & POIs : Entry point for MSRC resources.
4	Apple Security Releases Link(s) : support.apple.com/en-us/100100 Access / Cost : Free public	Relevance : Apple security release index. Notes & POIs : Important for iOS, macOS, Safari, watchOS, tvOS, & ecosystem patch tracking.
5	Google Android Security Bulletins Link(s) : source.android.com/docs/security/bulletin Access / Cost : Free public	Relevance : Android platform security bulletins. Notes & POIs : Device/vendor patch latency may differ from bulletin availability.
6	Google Chrome Releases Link(s) : chromereleases.googleblog.com Access / Cost : Free public	Relevance : Chrome release announcements. Notes & POIs : Security fixes are often disclosed with delayed details.
7	Chrome security advisories	Relevance : Chrome security-specific release posts.

Sl. #	Source Title	Notes
	Link(s) : chromereleases.googleblog.com/search/label/Security Access / Cost : Free public	Notes & POIs : Good for urgent browser vulnerability tracking.
8	Chromium issue tracker Link(s) : issues.chromium.org Access / Cost : Free public for public issues; restricted issues may require access	Relevance : Chromium issue tracking. Notes & POIs : Security bugs may have restricted visibility until disclosure.
9	Mozilla Security Advisories Link(s) : www.mozilla.org/en-US/security/advisories Access / Cost : Free public	Relevance : Mozilla security advisories. Notes & POIs : Important for Firefox, Thunderbird, & related products.
10	Mozilla Foundation Security Advisories Link(s) : www.mozilla.org/en-US/security/known-vulnerabilities Access / Cost : Free public	Relevance : Mozilla known vulnerabilities index. Notes & POIs : Useful for historical advisory lookup.
11	Google Cloud Security Bulletins Link(s) : cloud.google.com/support/bulletins Access / Cost : Free public	Relevance : Google Cloud service/product security bulletins. Notes & POIs : Cloud advisories often require service-specific interpretation.
12	Kubernetes Security Announcements Link(s) : groups.google.com/g/kubernetes-security-announce Access / Cost : Free public Google Group	Relevance : Kubernetes security announcement mailing list. Notes & POIs : Authoritative operational alerting channel for Kubernetes CVEs.
13	Kubernetes official CVE feed Link(s) : kubernetes.io/docs/reference/issues-security/official-cve-feed Access / Cost : Free public	Relevance : Official Kubernetes CVE feed reference. Notes & POIs : Useful for automation & Kubernetes-specific CVE tracking.
14	Kubernetes security & disclosure Link(s) : kubernetes.io/docs/reference/issues-security/security Access / Cost : Free public	Relevance : Kubernetes security disclosure process. Notes & POIs : Useful for understanding embargo, disclosure, & patch handling.

10.2 Enterprise infrastructure vendors

Sl. #	Source Title	Notes
1	Cisco Security Advisories Link(s) : sec.cloudapps.cisco.com/security/center/publicationListing.x Access / Cost : Free public	Relevance : Cisco product advisories, affected versions, fixed versions, & workarounds. Notes & POIs : Critical for network infrastructure exposure.
2	VMware / Broadcom Security Advisories Link(s) : support.broadcom.com/web/ecx/security-advisory	Relevance : VMware/Broadcom security advisories. Notes & POIs : Important for virtualization ESXi, vCenter, & enterprise infrastructure.

Sl. #	Source Title	Notes
	Access / Cost : Free public listing; some support downloads may require entitlement	
3	Palo Alto Networks Security Advisories Link(s) : security.paloaltonetworks.com Access / Cost : Free public	Relevance : PAN-OS & Palo Alto product advisories. Notes & POIs : Often includes exploit-the-wild notes & mitigation guidance.
4	Fortinet PSIRT Advisories Link(s) : www.fortiguard.com/psirt Access / Cost : Free public	Relevance : Fortinet product advisories. Notes & POIs : Critical for perimeter defense; exploitability can change quickly.
5	Ivanti Security Advisories Link(s) : forums.ivanti.com/s/security-advisory Access / Cost : Free public	Relevance : Ivanti security advisories. Notes & POIs : Track emergency advisories closely due to recurring exploitation patterns.
6	Citrix Security Bulletins Link(s) : support.citrix.com/securitybulletins Access / Cost : Free public	Relevance : Citrix product security bulletins. Notes & POIs : Useful for exposed remote access infrastructure.
7	F5 Security Advisories Link(s) : my.f5.com/manage/s/solutions?series=Security_Advisory Access / Cost : Free public listing; some support content may require account	Relevance : F5 product security advisories. Notes & POIs : Product modules/configuration affect exploitation.
8	Juniper Security Advisories Link(s) : supportportal.juniper.net/s/global-search/%40uri#sort=relevancy&f:ctype=[Security%20Advisories] Access / Cost : Free public listing; support portal may require account for some content	Relevance : Juniper security advisories. Notes & POIs : Useful for network infrastructure patching.
9	Dell Security Advisories Link(s) : www.dell.com/support/security Access / Cost : Free public listing; downloads/support may require entitlement	Relevance : Dell product security advisories. Notes & POIs : Covers firmware, hardware drivers, & enterprise products.
10	HPE Security Bulletins Link(s) : support.hpe.com/connect/s/securitybulletins Access / Cost : Free public listing; support portal may require account/entitlement	Relevance : HPE security bulletins. Notes & POIs : May require product-specific support portal navigation.
11	Lenovo Product Security Advisories Link(s) : support.lenovo.com/us/en/product_security/home Access / Cost : Free public	Relevance : Lenovo product security advisories. Notes & POIs : Useful for firmware & fleet management.
12	IBM PSIRT Link(s) : www.ibm.com/support/pages/ibm-psirt Access / Cost : Free public listing; some IBM support docs may require entitlement	Relevance : IBM product security incident response. Notes & POIs : Useful for IBM software/hardware exposure.

Sl. #	Source Title	Notes
13	SAP Security Notes Link(s) : support.sap.com/en/my-support/knowledge-base/security-notes-news.html Access / Cost : SAP support account / subscription often required for full Security Notes	Relevance : SAP security notes & patch guidance. Notes & POIs : May require SAP support access for full note details.
14	Adobe Security Bulletins Link(s) : helpx.adobe.com/security.html Access / Cost : Free public	Relevance : Adobe security bulletins. Notes & POIs : Important for client-side enterprise Adobe software.
15	Oracle Critical Patch Updates Link(s) : www.oracle.com/security-alerts Access / Cost : Free public	Relevance : Oracle CPU, Security Alerts CVE mappings. Notes & POIs : Oracle advisories often cover many products; mapping requires product/version context.
16	Atlassian Security Advisories	www.atlassian.com/trust/security/advisories
17	Elastic Security Announcements	discuss.elastic.co/c/announcements/s/announcements/31
18	HashiCorp Security	www.hashicorp.com/security
19	GitLab Security Releases	about.gitlab.com/releases/categories/
20	Jenkins Security Advisories	www.jenkins.io/security/advisories
21	Apache Security Reports	www.apache.org/security
22	Eclipse Security Advisories	www.eclipse.org/security
23	WordPress Security Releases	wordpress.org/news/category/security
24	Drupal Security Advisories	www.drupal.org/security
25	OpenSSL Vulnerabilities	www.openssl.org/news/vulnerabilities
26	OpenSSH release notes	www.openssh.com/releasenotes.html
27	curl security advisories	curl.se/docs/security.html

10.3 Cloud provider security bulletins

Sl. #	Source Title	Notes
1	AWS Security Bulletins Link(s) : aws.amazon.com/security/security-bulletins Access / Cost : Free public	Relevance : AWS service/product security bulletins. Notes & POIs : Cloud provider advisories often require service/configuration context.
2	AWS Security Blog Link(s) : aws.amazon.com/blogs/security Access / Cost : Free public	Relevance : AWS security guidance & incident context. Notes & POIs : Good for mitigation patterns, not canonical CVE data.
3	Google Cloud Security Bulletins Link(s) : cloud.google.com/support/bulletins Access / Cost : Free public	Relevance : Google Cloud security bulletins. Notes & POIs : Use with asset inventory & managed service exposure.

Sl. #	Source Title	Notes
4	Google Cloud Security Blog Link(s) : cloud.google.com/blog/products/identity-security Access / Cost : Free public	Relevance : Google Cloud identity/security blog. Notes & POIs : Useful for operational context & mitigations.
5	Microsoft Azure security / MSRC Link(s) : msrc.microsoft.com/update-guide Access / Cost : Free public	Relevance : Microsoft/Azure-related security updates. Notes & POIs : Azure service advisories may require separate portal/status checks.
6	Azure updates Link(s) : azure.microsoft.com/en-us/updates Access / Cost : Free public	Relevance : Azure product update feed. Notes & POIs : Not purely security-specific; filter carefully.
7	Oracle Cloud security Link(s) : www.oracle.com/security-alerts Access / Cost : Free public	Relevance : Oracle cloud/product security alerts. Notes & POIs : Oracle advisories often span cloud & on-prem products.
8	IBM Cloud security bulletins	cloud.ibm.com/status/security

[Back to Index](#)

11. ICS, OT, IoT, embedded & medical-device sources

11.1 CISA ICS / medical

Sl. #	Source Title	Notes
1	CISA ICS Advisories Link(s) : www.cisa.gov/news-events/ics-advisories Access / Cost : Free public	Relevance : Industrial Control System advisories. Notes & POIs : Critical for OT/ICS environments where patching constraints differ from IT.
2	CISA ICS Medical Advisories Link(s) : www.cisa.gov/news-events/ics-medical-advisories Access / Cost : Free public	Relevance : Medical device security advisories. Notes & POIs : Impact includes patient safety, regulatory, & operational risk.
3	CISA cybersecurity advisories Link(s) : www.cisa.gov/cybersecurity-advisories Access / Cost : Free public	Relevance : CISA cybersecurity advisory hub. Notes & POIs : Broader than ICS; use for campaigns & emergent threats.
4	ICS-CERT advisories archive Link(s) : www.cisa.gov/news-events/ics-advisories Access / Cost : Free public	Relevance : ICS-CERT advisory archive path. Notes & POIs : Same URL as ICS advisories, preserved for historical naming.
5	CISA ICS recommended practices Link(s) : www.cisa.gov/resources-	Relevance : Recommended practices for ICS security.

Sl. #	Source Title	Notes
	tools/resources/ics-recommended-practices Access / Cost : Free public	Notes & POIs : Useful for mitigation where patching is delayed or impossible.

11.2 OT / ICS vendor advisories

Sl. #	Source Title	Notes
1	Siemens ProductCERT Link(s) : cert-portal.siemens.com/productcert Access / Cost : Free public advisories; some support downloads may require entitlement	Relevance : Siemens product security advisories. Notes & POIs : Critical for industrial environments.
2	Schneider Electric Security Notifications Link(s) : www.se.com/ww/en/work/support/cybersecurity/security-notifications.jsp Access / Cost : Free public	Relevance : Schneider Electric security notifications. Notes & POIs : Product model & firmware version matter heavily.
3	Rockwell Automation Security Advisories Link(s) : www.rockwellautomation.com/en-us/support/product/product-security-advisories.html Access / Cost : Free public listing; support downloads may require entitlement	Relevance : Rockwell Automation product advisories. Notes & POIs : Operational constraints may affect remediation.
4	Honeywell Product Security Link(s) : www.honeywell.com/us/en/product-security Access / Cost : Free public	Relevance : Honeywell product security advisories. Notes & POIs : Useful for OT product risk.
5	Philips Product Security Link(s) : www.philips.com/a-w/security/security-advisories.html Access / Cost : Free public	Relevance : Philips medical/product security advisories. Notes & POIs : Patient safety & regulatory implications may affect severity assessment.
6	GE Vernova Product Security Link(s) : www.gevernova.com/product-security Access / Cost : Free public	Relevance : GE Vernova product security. Notes & POIs : Important for energy/industrial systems.
7	ABB Cyber Security Alerts Link(s) : global.abb/group/en/technology/cyber-security/alerts-and-notifications Access / Cost : Free public	Relevance : ABB cyber security alerts & notifications. Notes & POIs : Product-specific affectedness matters.
8	Yokogawa Security Advisories Link(s) : www.yokogawa.com/library/resources/white-papers/yokogawa-security-advisory-report-list Access / Cost : Free public	Relevance : Yokogawa advisory report list. Notes & POIs : Useful for OT control systems.
9	Mitsubishi Electric PSIRT	Relevance : Mitsubishi Electric vulnerability advisories.

Sl. #	Source Title	Notes
	Link(s) : www.mitsubishielectric.com/en/psirt/vulnerability Access / Cost : Free public	Notes & POIs : Important for industrial equipment & automation.
10	Johnson Controls Product Security Advisories Link(s) : www.johnsoncontrols.com/cyber-solutions/security-advisories Access / Cost : Free public	Relevance : Johnson Controls security advisories. Notes & POIs : Relevant to building management & OT environments.

11.3 IoT / embedded

Sl. #	Source Title	Notes
1	CERT/CC Vulnerability Notes Link(s) : www.kb.cert.org/vuls Access / Cost : Free public	Relevance : Coordinated disclosure notes, often with embedded/IoT affected vendors. Notes & POIs : Useful when many vendors share a vulnerable component.
2	IoT Security Foundation Link(s) : www.iotsecurityfoundation.org Access / Cost : Free public resources; membership options may exist	Relevance : IoT security guidance & resources. Notes & POIs : Not a vulnerability feed, but useful for control mapping.
3	Firmware Analysis and Comparison Tool - FACT Link(s) : github.com/fkie-cad/FACT_core Access / Cost : Free / open-source public GitHub repo	Relevance : Firmware analysis platform. Notes & POIs : Useful for extracting components & embedded vuln detection.
4	EMBA firmware analyzer Link(s) : github.com/e-m-b-a/emba Access / Cost : Free / open-source public GitHub repo	Relevance : Firmware analyzer for embedded Linux/IoT. Notes & POIs : Useful for SBOM-like extraction & vulnerability assessment.
5	Binwalk Link(s) : github.com/ReFirmLabs/binwalk Access / Cost : Free / open-source public GitHub repo	Relevance : Firmware extraction & analysis tool. Notes & POIs : Useful precursor for embedded component discovery.

[Back to Index](#)

E. Security Supply Chain Evidence: SBOM, VEX, Provenance & Malicious Package Risk

12. SBOM, package identity, VEX & advisory exchange standards

12.1 SBOM standards

Sl. #	Source Title	Notes
1	CycloneDX specification overview Link(s) : cyclonedx.org/specification/overview Access / Cost : Free / open standard	Relevance : SBOM, SaaSOM, BOM, VEX, vulnerability & component metadata standard. Notes & POIs : Good fit for vulnerability management workflows due to vulnerability & VEX support.
2	CycloneDX GitHub Link(s) : github.com/CycloneDX/specification Access / Cost : Free / open-source public GitHub repo	Relevance : CycloneDX specification source repository. Notes & POIs : Use for versioned spec tracking.
3	CycloneDX VEX Link(s) : cyclonedx.org/capabilities/vex Access / Cost : Free public docs	Relevance : CycloneDX VEX capability documentation. Notes & POIs : Useful for affected/not-affected communication.
4	SPDX specifications Link(s) : spdx.dev/specifications Access / Cost : Free / open standard	Relevance : SPDX specifications for software bills of materials & package metadata. Notes & POIs : SPDX is widely used for license/package metadata & supply-chain exchange.
5	SPDX 3.0.1 spec Link(s) : spdx.github.io/spdx-spec/v3.0.1 Access / Cost : Free public docs	Relevance : SPDX 3.0.1 specification. Notes & POIs : Track spec version compatibility in parsers.
6	SPDX package URL property Link(s) : spdx.github.io/spdx-spec/v3.0.1/model/Software/Properties/packageUrl Access / Cost : Free public docs	Relevance : SPDX support for package URL property. Notes & POIs : Important for PURL-based vulnerability matching.
7	SPDX GitHub Link(s) : github.com/spdx/spdx-spec Access / Cost : Free / open-source public GitHub repo	Relevance : SPDX specification repository. Notes & POIs : Use for release tracking & schema/source inspection.
8	NTIA SBOM resources Link(s) : www.ntia.gov/page/software-bill-materials Access / Cost : Free public	Relevance : SBOM policy & foundational resources. Notes & POIs : Useful for governance & compliance context.
9	CISA SBOM Link(s) : www.cisa.gov/sbom Access / Cost : Free public	Relevance : CISA SBOM guidance & resources. Notes & POIs : Useful for U.S. public-sector & enterprise SBOM program alignment.

12.2 Package & software identity

Sl. #	Source Title	Notes
1	Package URL - PURL spec Link(s) : github.com/package-url/purl-spec	Relevance : Standard package identifier used in SBOMs & vulnerability DBs.

Sl. #	Source Title	Notes
	Access / Cost : Free / open-source public GitHub repo	Notes & POIs : Crucial for OSV & package ecosystem matching.
2	PURL types Link(s) : github.com/package-url/purl-spec/blob/master/PURL-TYPES.rst Access / Cost : Free public	Relevance : Defines PURL types per ecosystem. Notes & POIs : Helps normalize ecosystem-specific package coordinates.
3	CPE specification / dictionary Link(s) : nvd.nist.gov/products/cpe Access / Cost : Free public	Relevance : Product naming & CPE dictionary. Notes & POIs : Useful for product/platform matching, but can be imprecise for packages.
4	NVD CPE API Link(s) : nvd.nist.gov/developers/products Access / Cost : Free public; optional free API key for higher rate limits	Relevance : Programmatic CPE dictionary access. Notes & POIs : Required for automated CPE matching workflows.
5	SWID tags - NIST Link(s) : csrc.nist.gov/projects/software-identification-swid Access / Cost : Free public	Relevance : Software Identification Tags for installed software identity. Notes & POIs : Useful in enterprise asset inventory & compliance.
6	GS1 Digital Link / identifiers Link(s) : www.gs1.org/standards/gs1-digital-link Access / Cost : Free public standard docs; GS1 membership may apply for assigned identifiers	Relevance : Optional identity standard for physical/embedded supply chains. Notes & POIs : Not a vulnerability standard, but can matter in hardware/product traceability.
7	Software Heritage IDs Link(s) : www.swhid.org Access / Cost : Free public / open	Relevance : Persistent source- code artifact identity. Notes & POIs : Useful for source provenance & precise code artifact references.

12.3 Advisory exchange, CSAF & VEX

Sl. #	Source Title	Notes
1	OASIS CSAF 2.0 specification Link(s) : docs.oasis-open.org/csaf/csaf/v2.0/os/csaf-v2.0-os.html Access / Cost : Free / open standard	Relevance : Common Security Advisory Framework for structured advisories. Notes & POIs : CSAF can express product status, remediation, impact, & VEX-like affectedness.
2	CSAF home Link(s) : www.csaf.io Access / Cost : Free public	Relevance : CSAF ecosystem & tooling hub. Notes & POIs : Good starting point for CSAF adoption.
3	OpenVEX specification Link(s) : github.com/openvex/spec Access / Cost : Free / open-source public GitHub repo	Relevance : Minimal JSON-LD VEX format based on CISA VEX requirements. Notes & POIs : Useful for communicating not- affected/fixed/affected status.

Sl. #	Source Title	Notes
4	OpenVEX project page Link(s) : openssf.org/projects/openvex Access / Cost : Free public	Relevance : OpenSSF project page for OpenVEX. Notes & POIs : Project-level overview.
5	CISA Minimum Requirements for VEX Link(s) : www.cisa.gov/sites/default/files/2023-04/minimum-requirements-for-vex-508c.pdf Access / Cost : Free public PDF	Relevance : Baseline VEX requirements. Notes & POIs : Useful for evaluating VEX completeness.
6	OpenSSF VDR, VEX, OpenVEX & CSAF explainer Link(s) : openssf.org/blog/2023/09/07/vdr-vex-openvex-and-csaf Access / Cost : Free public	Relevance : Explains VDR, VEX, OpenVEX, & CSAF. Notes & POIs : Useful for conceptual alignment & terminology.
7	Red Hat CSAF/VEX guidance Link(s) : redhatproductsecurity.github.io/security-data-guidelines/csaf-vex Access / Cost : Free public docs	Relevance : Red Hat CSAF/VEX semantics & usage guidance. Notes & POIs : Important for vendor-specific interpretation.
8	Ubuntu VEX Link(s) : ubuntu.com/security/vex Access / Cost : Free public	Relevance : Ubuntu VEX data entry point. Notes & POIs : Useful for Ubuntu affectedness & false-positive reduction.
9	Canonical Ubuntu Security Notices repo - OSV & OpenVEX Link(s) : github.com/canonical/ubuntu-security-notices Access / Cost : Free public GitHub repo	Relevance : Canonical USN/LSN, OSV, & OpenVEX JSON data. Notes & POIs : Strong machine-readable source for Ubuntu security status.

[Back to Index](#)

13. Malicious package, supply-chain compromise & package reputation sources

13.1 Malicious package databases

Sl. #	Source Title	Notes
1	OpenSSF Malicious Packages repository Link(s) : github.com/ossf/malicious-packages Access / Cost : Free / open-source public GitHub repo	Relevance : Public malicious package reports consumable via OSV format. Notes & POIs : Covers malicious packages, which may not be CVEs.
2	OpenSSF Malicious Packages announcement Link(s) : openssf.org/blog/2023/10/12/introducing-openssfs-malicious-packages-repository Access / Cost : Free public	Relevance : Explains the public DB for malicious package reports. Notes & POIs : Context source, not the primary data feed.
3	OpenSSF Package Analysis Link(s) : openssf.org/package-analysis	Relevance : Detects malicious package behavior & informs package consumers.

Sl. #	Source Title	Notes
	Access / Cost : Free public project info	Notes & POIs : Behavioral analysis may surface packages before CVE/advisory assignment.
4	OpenSSF Package Analysis GitHub Link(s) : github.com/ossf/package-analysis Access / Cost : Free / open-source public GitHub repo	Relevance : Open-source package analysis system. Notes & POIs : Useful for detection logic & behavioral signal review.
5	OpenSSF Package Feeds Link(s) : github.com/ossf/package-feeds Access / Cost : Free / open-source public GitHub repo	Relevance : Package ecosystem feed monitoring. Notes & POIs : Useful for observing new packages in ecosystems.
6	GitHub malware advisories Link(s) : github.com/advisories?query=type%3Amalware Access / Cost : Free public	Relevance : GitHub malware advisories across ecosystems. Notes & POIs : Treat as supply-chain compromise data, not conventional vuln data.
7	npm malware advisories via GitHub	github.com/advisories?query=ecosystem%3Anpm+type%3Amalware
8	PyPI malware advisories via GitHub	github.com/advisories?query=ecosystem%3Apip+type%3Amalware
9	Socket.dev blog	socket.dev/blog
10	Snyk vulnerability database	security.snyk.io
11	Sonatype OSS Index	ossindex.sonatype.org
12	Sonatype vulnerability database	sonatype.com/resources/vulnerability-database
13	Phylum research	blog.phylum.io
14	ReversingLabs threat research	www.reversinglabs.com/blog
15	Checkmarx supply-chain research	checkmarx.com/blog

13.2 Package reputation / dependency health

Sl. #	Source Title	Notes
1	OpenSSF Scorecard Link(s) : github.com/ossf/scorecard Access / Cost : Free / open-source public GitHub repo	Relevance : Scores open-source project security practices. Notes & POIs : Useful as dependency risk signal, not vulnerability proof.
2	OpenSSF Scorecard API Link(s) : api.securityscorecards.dev Access / Cost : Free public API subject to service limits	Relevance : API for Scorecard results. Notes & POIs : Use with timestamped results because scores change over time.
3	OpenSSF Best Practices Badge Link(s) : www.bestpractices.dev Access / Cost : Free public	Relevance : Project best-practices badge program. Notes & POIs : Useful project maturity signal, not vulnerability evidence.
4	deps.dev Link(s) : deps.dev	Relevance : Dependency metadata, transitive dependencies, security signals.

Sl. #	Source Title	Notes
	Access / Cost : Free public	Notes & POIs : Useful for dependency graphing & package metadata.
5	OpenSSF GUAC Link(s) : guac.sh Access / Cost : Free public / open-source project	Relevance : Graph for software supply- chain metadata. Notes & POIs : Useful for correlating SBOMs, attestations, vulnerabilities, & provenance.
6	GUAC GitHub Link(s) : github.com/guacsec/guac Access / Cost : Free / open-source public GitHub repo	Relevance : GUAC implementation repository. Notes & POIs : Reference architecture for supply-chain knowledge graphs.
7	Sigstore Link(s) : www.sigstore.dev Access / Cost : Free / open-source public infrastructure	Relevance : Signing & verification for software artifacts. Notes & POIs : Helps assess provenance & tamper resistance.
8	Rekor transparency log Link(s) : docs.sigstore.dev/logging/overview Access / Cost : Free public docs / public transparency log	Relevance : Transparency log for signed artifacts. Notes & POIs : Useful for provenance verification & audit trails.
9	SLSA framework Link(s) : slsa.dev Access / Cost : Free / open standard	Relevance : Supply-chain Levels for Software Artifacts. Notes & POIs : Helps assess build integrity & supply-chain hardening.

[Back to Index](#)

14. Source-code, dependency, artifact & build-chain provenance

14.1 Source & artifact provenance

Sl. #	Source Title	Notes
1	SLSA Link(s) : slsa.dev Access / Cost : Free / open standard	Relevance : Supply-chain Levels for Software Artifacts. Notes & POIs : Useful for evaluating build integrity & provenance risk.
2	Sigstore Link(s) : www.sigstore.dev Access / Cost : Free / open-source public infrastructure	Relevance : Signing & verification for software artifacts. Notes & POIs : Helps verify artifact integrity & publisher identity.
3	Cosign Link(s) : github.com/sigstore/cosign Access / Cost : Free / open-source public GitHub repo	Relevance : Container/artifact signing tool. Notes & POIs : Useful for verifying container image provenance.

Sl. #	Source Title	Notes
4	Rekor Link(s) : docs.sigstore.dev/logging/overview Access / Cost : Free public docs / public transparency log	Relevance : Transparency log for signed artifacts. Notes & POIs : Useful for auditability & tamper detection.
5	in-toto Link(s) : in-toto.io Access / Cost : Free / open-source	Relevance : Supply-chain integrity framework. Notes & POIs : Useful for verifying build steps & provenance attestations.
6	The Update Framework - TUF Link(s) : theupdateframework.io Access / Cost : Free / open-source	Relevance : Secure software update framework. Notes & POIs : Useful for update-channel compromise resistance.
7	SLSA GitHub generators Link(s) : github.com/slsa-framework/slsa-github-generator Access / Cost : Free / open-source public GitHub repo	Relevance : GitHub-based SLSA provenance generators. Notes & POIs : Useful for CI/CD provenance generation.

14.2 Dependency inventory & graphing

Sl. #	Source Title	Notes
1	deps.dev	deps.dev
2	GUAC	guac.sh
3	GUAC GitHub	github.com/guacsec/guac
4	OpenSSF Scorecard	github.com/ossf/scorecard
5	OpenSSF Scorecard API	api.securityscorecards.dev
6	Maven Central	central.sonatype.com
7	npm registry	registry.npmjs.org
8	PyPI JSON API	docs.pypi.org/api/json
9	crates.io API	crates.io/data-access
10	Go module proxy	proxy.golang.org

[Back to Index](#)

F. Detection, Exposure, Threat Telemetry, Validation & Remediation Operations

15. Automated vulnerability detection, static analysis, dynamic analysis & research datasets

15.1 SAST / code query engines

Sl. #	Source Title	Notes
1	CodeQL Link(s) : codeql.github.com Access / Cost : Free for many open-source uses; GitHub Advanced Security commercial for private enterprise use	Relevance : Semantic code analysis engine for vulnerability discovery. Notes & POIs : Strong for variant analysis & source-level detection.
2	CodeQL GitHub Link(s) : github.com/github/codeql Access / Cost : Free / open-source public GitHub repo	Relevance : CodeQL source & query repository. Notes & POIs : Use query packs for detection logic examples.
3	CodeQL query packs Link(s) : github.com/github/codeql/tree/main Access / Cost : Free / open-source public GitHub repo	Relevance : Query packs for multiple languages. Notes & POIs : Queries can be adapted for custom vuln detection.
4	Semgrep Link(s) : semgrep.dev Access / Cost : Free/open-source CLI; commercial Semgrep products available	Relevance : Pattern-based static analysis. Notes & POIs : Good for fast custom rule writing.
5	Semgrep rules Link(s) : github.com/semgrep/semgrep-rules Access / Cost : Free / open-source public GitHub repo	Relevance : Community/official Semgrep rules. Notes & POIs : Validate rule precision before production blocking.
6	Joern Link(s) : joern.io Access / Cost : Free / open-source core	Relevance : Code property graph platform. Notes & POIs : Useful for research-grade vulnerability discovery.
7	Joern GitHub Link(s) : github.com/joernio/joern Access / Cost : Free / open-source public GitHub repo	Relevance : Joern implementation. Notes & POIs : Useful for custom graph queries & ML pipelines.
8	Facebook Infer Link(s) : fbinfer.com Access / Cost : Free public / open-source	Relevance : Static analyzer for multiple languages. Notes & POIs : Useful for null deref, resource leaks, concurrency, & related bug classes.
9	Infer GitHub Link(s) : github.com/facebook/infer Access / Cost : Free / open-source public GitHub repo	Relevance : Infer source repository. Notes & POIs : Reference implementation.
10	SonarQube rules Link(s) : rules.sonarsource.com Access / Cost : Free public rules catalog; Sonar products include free & commercial tiers	Relevance : SonarSource rule catalog. Notes & POIs : Useful for mapping code quality/security rules to weakness classes.
11	Bandit - Python Link(s) : github.com/PyCQA/bandit	Relevance : Python security linter. Notes & POIs : Useful for Python SAST coverage.

Sl. #	Source Title	Notes
	Access / Cost : Free / open-source public GitHub repo	
12	Gosec - Go Link(s) : github.com/securego/gosec Access / Cost : Free / open-source public GitHub repo	Relevance : Go security checker. Notes & POIs : Useful for Go SAST.
13	ESLint security plugin Link(s) : github.com/eslint-community/eslint-plugin-security Access / Cost : Free / open-source public GitHub repo	Relevance : JavaScript security lint rules. Notes & POIs : Useful for JS static checks.
14	SpotBugs Link(s) : spotbugs.github.io Access / Cost : Free / open-source	Relevance : Java static analysis. Notes & POIs : General bug detection; pair with FindSecBugs for security.
15	FindSecBugs Link(s) : find-sec-bugs.github.io Access / Cost : Free / open-source	Relevance : Java security bug detection plugin. Notes & POIs : Useful for Java/JVM SAST.
16	Clang Static Analyzer Link(s) : clang-analyzer.llvm.org Access / Cost : Free / open-source	Relevance : C/C++/Objective-C static analyzer. Notes & POIs : Useful for native code vulnerability classes.
17	Cppcheck Link(s) : cppcheck.sourceforge.io Access / Cost : Free / open-source	Relevance : C/C++ static analyzer. Notes & POIs : Complements compiler analyzers.
18	Flawfinder Link(s) : dwheeler.com/flawfinder Access / Cost : Free / open-source	Relevance : C/C++ security scanner for dangerous functions. Notes & POIs : Fast heuristic scanner with false-positive risk.
19	Brakeman - Ruby on Rails Link(s) : brakemanscanner.org Access / Cost : Free / open-source	Relevance : Ruby on Rails static security scanner. Notes & POIs : Useful for Rails-specific vulnerability patterns.
20	Horusec Link(s) : github.com/ZupIT/horusec Access / Cost : Free / open-source public GitHub repo	Relevance : Multi-language security scanner. Notes & POIs : Useful for broad SAST coverage.
21	Bearer Link(s) : github.com/Bearer/bearer Access / Cost : Free / open-source public GitHub repo	Relevance : Code security/privacy scanner. Notes & POIs : Useful for data-flow & sensitive data exposure detection.
22	MobSF Link(s) : github.com/MobSF/Mobile-Security-Framework-MobSF	Relevance : Mobile security testing framework. Notes & POIs : Useful for Android/iOS static & dynamic app analysis.

Sl. #	Source Title	Notes
	Access / Cost : Free / open-source public GitHub repo	
23	zizmor Link(s) : github.com/zizmorcore/zizmor Access / Cost : Free / open-source public GitHub repo	Relevance : Static analysis for GitHub Actions. Notes & POIs : Useful for CI/CD workflow security, GitHub Actions hardening, & supply-chain pipeline risk detection.
24	OpenAnt Link(s) : github.com/knastic/OpenAnt Access / Cost : Free / open-source public GitHub repo	Relevance : LLM-based vulnerability discovery product focused on verified security flaws & reduced false positives. Notes & POIs : Useful as AI-assisted vulnerability discovery tooling. Validate findings against primary evidence before treating as confirmed vulnerabilities.

15.2 DAST, IAST, fuzzing & dynamic test sources

Sl. #	Source Title	Notes
1	OSS-Fuzz Link(s) : google.github.io/oss-fuzz Access / Cost : Free for eligible open-source projects	Relevance : Continuous fuzzing for open-source projects. Notes & POIs : Useful for vulnerability discovery & bug lifecycle data.
2	OSS-Fuzz GitHub Link(s) : github.com/google/oss-fuzz Access / Cost : Free / open-source public GitHub repo	Relevance : OSS-Fuzz project configuration repository. Notes & POIs : Useful for project fuzzing coverage & harness examples.
3	OSS-Fuzz vulnerability data in OSV Link(s) : osv.dev/list?ecosystem=OSS-Fuzz Access / Cost : Free public	Relevance : OSV records from OSS-Fuzz vulnerabilities. Notes & POIs : Good for linking fuzz-discovered vulnerabilities to OSV schema.
4	ClusterFuzzLite Link(s) : google.github.io/clusterfuzzlite Access / Cost : Free / open-source	Relevance : Lightweight continuous fuzzing for CI/CD. Notes & POIs : Useful for integrating fuzzing into development pipelines.
5	AFL++ Link(s) : github.com/AFLplusplus/AFLplusplus Access / Cost : Free / open-source public GitHub repo	Relevance : Coverage-guided fuzzer. Notes & POIs : Good for native code vulnerability discovery.
6	libFuzzer Link(s) : llvm.org/docs/LibFuzzer.html Access / Cost : Free / open-source LLVM component	Relevance : In-process coverage-guided fuzzer. Notes & POIs : Common with LLVM sanitizers.
7	Honggfuzz Link(s) : github.com/google/honggfuzz Access / Cost : Free / open-source public GitHub repo	Relevance : Security-oriented fuzzer. Notes & POIs : Useful for native code dynamic testing.
8	Jazzer	Relevance : JVM fuzzing engine.

Sl. #	Source Title	Notes
	Link(s) : github.com/CodeIntelligenceTesting/jazzer Access / Cost : Free / open-source public GitHub repo	Notes & POIs : Useful for Java/Kotlin fuzz testing.
9	OWASP ZAP Link(s) : www.zaproxy.org Access / Cost : Free / open-source	Relevance : Web application dynamic security scanner. Notes & POIs : Useful for DAST & app exposure validation.
10	Nuclei Link(s) : github.com/projectdiscovery/nuclei Access / Cost : Free / open-source public GitHub repo; commercial ecosystem separate	Relevance : Template-based vulnerability & exposure scanner. Notes & POIs : Useful for automated exposed-service checks.
11	Nuclei templates Link(s) : github.com/projectdiscovery/nuclei-templates Access / Cost : Free / open-source public GitHub repo	Relevance : Community/official detection templates. Notes & POIs : Template quality varies; review false-positive potential.

15.3 Vulnerability-detection research datasets

Sl. #	Source Title	Notes
1	NIST SARD Link(s) : samate.nist.gov/SARD Access / Cost : Free public	Relevance : Software Assurance Reference Dataset. Notes & POIs : Useful for evaluating static analysis tools & ML models.
2	Juliet Test Suite - NIST SARD Link(s) : samate.nist.gov/SARD/test-suites/112 Access / Cost : Free public	Relevance : Synthetic test cases for many vulnerability classes. Notes & POIs : Useful for controlled evaluation, but may not reflect real-world code complexity.
3	Big-Vul Link(s) : github.com/ZeoVan/MSR_20_Code_vulnerability_CSV_Dataset Access / Cost : Free public GitHub repo; verify license	Relevance : Large vulnerability dataset derived from real-world CVE-fix commits. Notes & POIs : Validate deduplication, labels, & train/test leakage.
4	Devign Link(s) : sites.google.com/view/devign Access / Cost : Free public research page; verify dataset access/license	Relevance : Vulnerability detection dataset. Notes & POIs : Used in ML vuln detection research.
5	Draper VDISC Link(s) : osf.io/d45bw Access / Cost : Free public OSF dataset; verify license/terms	Relevance : Vulnerability discovery dataset. Notes & POIs : Useful for ML baselines; inspect labeling quality.
6	DiverseVul Link(s) : github.com/wagner-group/diversevul	Relevance : Diverse vulnerability dataset.

Sl. #	Source Title	Notes
	Access / Cost : Free public GitHub repo; verify license	Notes & POIs : Useful for model training/evaluation; check license & label quality.
7	PrimeVul Link(s) : github.com/DLVulDet/PrimeVul Access / Cost : Free public GitHub repo; verify license	Relevance : Vulnerability detection benchmark dataset. Notes & POIs : Useful for modern ML vulnerability detection benchmarking.
8	MegaVul	github.com/lcyrockton/MegaVul
9	Vul4J	github.com/tuhh-softsec/vul4j
10	VulnCode-DB	github.com/vegardit/vulncode-db
11	SecurityEval	github.com/s2e-lab/SecurityEval
12	CVEfixes	github.com/secureIT-project/CVEfixes
13	Defects4J	github.com/rjust/defects4j
14	ManySSuBs4J	github.com/mast-group/mineSSuBs
15	VulDeePecker	github.com/CGCL-codes/VulDeePecker

[Back to Index](#)

16. Exposure, internet-facing asset & threat telemetry

16.1 Internet exposure search engines

Sl. #	Source Title	Notes
1	Censys Search Link(s) : search.censys.io Access / Cost : Free tier / paid plans	Relevance : Internet exposure search engine. Notes & POIs : Useful for determining if vulnerable services are internet-facing.
2	Censys API Link(s) : search.censys.io/api Access / Cost : Free tier / paid plans; API key required	Relevance : Programmatic Censys access. Notes & POIs : API terms & quotas may apply.
3	Shodan Link(s) : www.shodan.io Access / Cost : Free limited access / paid plans	Relevance : Internet-connected device search. Notes & POIs : Useful for exposure discovery & banner-based matching.
4	Shodan developer API Link(s) : developer.shodan.io Access / Cost : Paid/API credit model may apply; account required	Relevance : Shodan API documentation. Notes & POIs : Useful for automation.
5	ZoomEye	www.zoomeye.org

Sl. #	Source Title	Notes
6	FOFA	fofa.info
7	BinaryEdge	www.binaryedge.io
8	Onyphe	www.onyphe.io
9	SecurityTrails	securitytrails.com
10	InternetDB by Shodan	internetdb.shodan.io

16.2 Scan/exploitation telemetry

Sl. #	Source Title	Notes
1	GreyNoise Visualizer Link(s) : viz.greynoise.io Access / Cost : Free tier / paid plans	Relevance : Internet scanning/exploitation telemetry. Notes & POIs : Helps separate background scanning from targeted activity.
2	GreyNoise API docs Link(s) : docs.greynoise.io Access / Cost : Free tier / paid plans; API key required	Relevance : API docs for GreyNoise enrichment. Notes & POIs : Useful for automated telemetry enrichment.
3	Shadowserver Link(s) : www.shadowserver.org Access / Cost : Free for eligible organizations; registration may be required	Relevance : Internet-scale exposure & threat telemetry. Notes & POIs : Good for population-level exposure signals.
4	Shadowserver reports Link(s) : dashboard.shadowserver.org Access / Cost : Free for eligible organizations; login/registration may be required	Relevance : Shadowserver reporting dashboard. Notes & POIs : Access/eligibility may vary.
5	SANS Internet Storm Center Link(s) : isc.sans.edu Access / Cost : Free public	Relevance : Internet threat telemetry & diary reports. Notes & POIs : Useful for emergent exploitation context.
6	Honeynet Project Link(s) : www.honeynet.org Access / Cost : Free public / open research	Relevance : Honeypot & threat research. Notes & POIs : Useful for attacker behavior insight.
7	DShield Link(s) : www.dshield.org Access / Cost : Free public / community	Relevance : Distributed intrusion detection & telemetry. Notes & POIs : Useful for broad scanning trend analysis.
8	LeakIX Link(s) : leakix.net Access / Cost : Free limited access / paid plans	Relevance : Exposed service & leak search. Notes & POIs : Useful for exposure assessment.
9	urlscan.io Link(s) : urlscan.io	Relevance : URL scanning & web telemetry.

Sl. #	Source Title	Notes
	Access / Cost : Free tier / paid plans	Notes & POIs : Useful for phishing, web exposure, & IOC enrichment.
10	VirusTotal Link(s) : www.virustotal.com Access / Cost : Free community access / paid enterprise plans	Relevance : File, URL, domain, & IP reputation. Notes & POIs : Useful for malware/IOC enrichment; licensing constraints apply.
11	VirusTotal API Link(s) : docs.virustotal.com/reference/overview Access / Cost : Free community API / paid enterprise API	Relevance : VirusTotal API documentation. Notes & POIs : API quota & data-sharing policies matter.

16.3 Attack surface management context

Sl. #	Source Title	Notes
1	Amass Link(s) : github.com/owasp-amass/amass Access / Cost : Free / open-source public GitHub repo	Relevance : Attack surface mapping & DNS enumeration. Notes & POIs : Useful for external asset discovery.
2	ProjectDiscovery Subfinder Link(s) : github.com/projectdiscovery/subfinder Access / Cost : Free / open-source public GitHub repo	Relevance : Subdomain discovery. Notes & POIs : Useful for asset inventory enrichment.
3	httpx Link(s) : github.com/projectdiscovery/httpx Access / Cost : Free / open-source public GitHub repo	Relevance : HTTP probing toolkit. Notes & POIs : Useful for validating exposed services.
4	Naabu Link(s) : github.com/projectdiscovery/naabu Access / Cost : Free / open-source public GitHub repo	Relevance : Port scanner. Notes & POIs : Useful for fast exposure discovery.
5	Nmap Link(s) : nmap.org Access / Cost : Free / open-source	Relevance : Network discovery & security auditing. Notes & POIs : Mature scanner for service detection & scripts.
6	Masscan Link(s) : github.com/robertdavidgraham/masscan Access / Cost : Free / open-source public GitHub repo	Relevance : High-speed port scanner. Notes & POIs : Use carefully; scan authorization & network impact matter.

17. Threat intelligence, malware, ransomware & in-the-wild exploitation context

17.1 Major threat research sources

Sl. #	Source Title	Notes
1	Mandiant / Google Cloud Threat Intelligence Link(s) : cloud.google.com/blog/topics/threat-intelligence Access / Cost : Free public blog; commercial threat intel products separate	Relevance : Threat intelligence & exploitation-in-the-wild context. Notes & POIs : Useful for campaign-level vulnerability exploitation context.
2	Microsoft Threat Intelligence blog Link(s) : www.microsoft.com/en-us/security/blog/topic/threat-intelligence Access / Cost : Free public blog	Relevance : Microsoft threat intel & exploitation reports. Notes & POIs : Useful for attacker behavior, exploitation campaigns, & mitigations.
3	Google Threat Analysis Group Link(s) : blog.google/threat-analysis-group Access / Cost : Free public blog	Relevance : Nation-state & high-end threat research. Notes & POIs : Useful for exploited-in-the-wild context.
4	Palo Alto Unit 42 Link(s) : unit42.paloaltonetworks.com Access / Cost : Free public blog; commercial threat intel services separate	Relevance : Threat research & vulnerability exploitation reporting. Notes & POIs : Useful for campaign & malware context.
5	Cisco Talos Link(s) : blog.talosintelligence.com Access / Cost : Free public blog; commercial Cisco products separate	Relevance : Threat intel, malware, & vulnerability research. Notes & POIs : Useful for IOCs & exploit campaigns.
6	Rapid7 vulnerability management blog Link(s) : www.rapid7.com/blog/tag/vulnerability-management Access / Cost : Free public blog; commercial products separate	Relevance : Vulnerability management & exploitability commentary. Notes & POIs : Useful for operational triage context.
7	Sophos X-Ops Link(s) : news.sophos.com/en-us/category/threat-research Access / Cost : Free public blog; commercial products separate	Relevance : Threat research & incident reports. Notes & POIs : Useful for exploitation context & malware behavior.
8	CrowdStrike Blog Link(s) : www.crowdstrike.com/en-us/blog Access / Cost : Free public blog; commercial products separate	Relevance : Threat intelligence & incident research. Notes & POIs : Useful for adversary behavior & vulnerability exploitation context.
9	SentinelOne Labs Link(s) : www.sentinelone.com/labs Access / Cost : Free public blog; commercial products separate	Relevance : Malware & threat research. Notes & POIs : Useful for exploit chains & malware analysis.

Sl. #	Source Title	Notes
10	Kaspersky Securelist Link(s) : securelist.com Access / Cost : Free public blog; commercial products separate	Relevance : Threat research & malware analysis. Notes & POIs : Useful for campaign-level context.
11	ESET WeLiveSecurity Link(s) : www.welivesecurity.com Access / Cost : Free public blog; commercial products separate	Relevance : Threat research & malware analysis. Notes & POIs : Useful for exploitation narratives & IOCs.
12	Trend Micro Research Link(s) : www.trendmicro.com/en_us/research.html Access / Cost : Free public research; commercial products separate	Relevance : Threat & vulnerability research. Notes & POIs : Useful for active exploitation context.
13	FortiGuard Labs Link(s) : www.fortiguards.com/research Access / Cost : Free public research; commercial products separate	Relevance : Fortinet threat research. Notes & POIs : Useful for attack patterns & indicators.
14	Check Point Research Link(s) : research.checkpoint.com Access / Cost : Free public blog; commercial products separate	Relevance : Threat research & vulnerability analysis. Notes & POIs : Useful for campaign & exploit analysis.
15	Elastic Security Labs Link(s) : www.elastic.co/security-labs Access / Cost : Free public research; commercial products separate	Relevance : Detection engineering & threat research. Notes & POIs : Useful for detection logic & adversary behavior.
16	Sekoia Threat Intelligence Link(s) : blog.sekoia.io Access / Cost : Free public blog; commercial threat intel separate	Relevance : Threat intelligence research. Notes & POIs : Useful for IOCs & campaign context.

17.2 Malware & IOC repositories

Sl. #	Source Title	Notes
1	MISP Link(s) : www.misp-project.org Access / Cost : Free / open-source; data sharing depends on communities/instances	Relevance : Threat intelligence sharing platform. Notes & POIs : Useful for IOC correlation & sharing.
2	AlienVault OTX Link(s) : otx.alienvault.com	Relevance : Open threat exchange for IOCs. Notes & POIs : Quality varies by pulse/source. Validate before enforcement.

Sl. #	Source Title	Notes
	Access / Cost : Free community access; commercial AT&T Cybersecurity products separate	
3	AbuseIPDB Link(s) : www.abuseipdb.com Access / Cost : Free tier / paid plans	Relevance : IP abuse reputation database. Notes & POIs : Useful for IP enrichment; not vulnerability-specific.
4	URLhaus Link(s) : urlhaus.abuse.ch Access / Cost : Free public	Relevance : Malware URL tracking. Notes & POIs : Useful for IOC enrichment.
5	MalwareBazaar Link(s) : bazaar.abuse.ch Access / Cost : Free public	Relevance : Malware sample sharing. Notes & POIs : Useful for malware family & hash enrichment.
6	ThreatFox Link(s) : threatfox.abuse.ch Access / Cost : Free public	Relevance : Threat intelligence indicators. Notes & POIs : Useful for IOCs.
7	Feodo Tracker Link(s) : feodotracker.abuse.ch Access / Cost : Free public	Relevance : Botnet C2 tracking. Notes & POIs : Useful for malware infrastructure context.
8	PhishTank Link(s) : phishtank.org Access / Cost : Free community access; API/account may be required	Relevance : Phishing URL database. Notes & POIs : Useful for phishing exposure & IOC enrichment.
9	OpenPhish Link(s) : openphish.com Access / Cost : Free limited feed / paid premium feeds	Relevance : Phishing intelligence. Notes & POIs : Commercial/community source; check terms.
10	YARA Link(s) : github.com/VirusTotal/yara Access / Cost : Free / open-source public GitHub repo	Relevance : Malware classification & pattern matching engine. Notes & POIs : Useful for detection signatures.
11	YARA-Rules Link(s) : github.com/Yara-Rules/rules Access / Cost : Free / open-source public GitHub repo	Relevance : Community YARA rules. Notes & POIs : Validate rule quality before production use.
12	SigmaHQ Link(s) : github.com/SigmaHQ/sigma Access / Cost : Free / open-source public GitHub repo	Relevance : Generic SIEM detection rule format. Notes & POIs : Useful for detection engineering.

Sl. #	Source Title	Notes
13	LOLBAS Link(s) : lolbas-project.github.io Access / Cost : Free public / open-source project	Relevance : Living-off-the-land binaries/scripts catalog. Notes & POIs : Useful for attack behavior detection.
14	GTFOBins Link(s) : gtfobins.github.io Access / Cost : Free public / open-source project	Relevance : Unix binary abuse catalog. Notes & POIs : Useful for privilege escalation & post-exploitation detection.
15	Ransomware.live Link(s) : www.ransomware.live Access / Cost : Free public	Relevance : Ransomware group/leak-site tracking. Notes & POIs : Useful for ransomware exploitation context & trend analysis.

[Back to Index](#)

G. Governance, Compliance, Assurance, Production Baselines & Final Operating Model

18. Compliance, baseline configuration, software assurance & exposure severity standards

These are not vulnerability feeds, but they help assess impact, control failure, configuration exposure, & exploitability in a given environment.

18.1 Security configuration & benchmarks

Sl. #	Source Title	Notes
1	CIS Benchmarks Link(s) : www.cisecurity.org/cis-benchmarks Access / Cost : Free with registration for many PDFs; commercial CIS tools/membership available	Relevance : Secure configuration benchmarks. Notes & POIs : Useful for environmental risk scoring & hardening validation.
2	CIS Controls Link(s) : www.cisecurity.org/controls Access / Cost : Free public	Relevance : Security control framework. Notes & POIs : Useful for vulnerability management program alignment.
3	NIST National Checklist Program Link(s) : ncp.nist.gov Access / Cost : Free public	Relevance : Repository of security configuration checklists. Notes & POIs : Useful for baseline configuration assessment.
4	DISA STIGs Link(s) : public.cyber.mil/stigs Access / Cost : Free public	Relevance : Security Technical Implementation Guides. Notes & POIs : Important for government/defense compliance.
5	OpenSCAP	Relevance : SCAP tooling for compliance scanning.

Sl. #	Source Title	Notes
	Link(s) : www.open-scap.org Access / Cost : Free / open-source	Notes & POIs : Useful for host-level configuration scanning.

| 6 | SCAP Security Guide | github.com/ComplianceAsCode/content | Free / open-source public GitHub repo | ComplianceAsCode content for SCAP profiles. | Useful for policy-as-code & baseline validation. |

18.2 Cloud configuration posture

Sl. #	Source Title	Notes
1	Prowler - AWS/Azure/GCP/Kubernetes Link(s) : github.com/prowler-cloud/prowler Access / Cost : Free / open-source core; commercial product available	Relevance : Cloud & Kubernetes security posture scanning. Notes & POIs : Useful for environmental exposure & misconfiguration risk.
2	CloudSplaining Link(s) : github.com/salesforce/cloudsplaining Access / Cost : Free / open-source public GitHub repo	Relevance : AWS IAM policy risk analysis. Notes & POIs : Useful for blast-radius & privilege exposure context.
3	ScoutSuite Link(s) : github.com/nccgroup/ScoutSuite Access / Cost : Free / open-source public GitHub repo	Relevance : Multi-cloud security auditing. Notes & POIs : Useful for cloud misconfiguration assessment.
4	Steampipe mods Link(s) : hub.steampipe.io/mods Access / Cost : Free/open-source mods; commercial Turbot/Steampipe offerings separate	Relevance : SQL-based cloud/security posture checks. Notes & POIs : Useful for custom exposure queries.
5	Cloud Custodian Link(s) : cloudcustodian.io Access / Cost : Free / open-source	Relevance : Cloud governance & policy automation. Notes & POIs : Useful for remediation automation.
6	Kubernetes CIS benchmark Link(s) : www.cisecurity.org/benchmark/kubernetes Access / Cost : Free with registration for benchmark PDFs; commercial CIS tools/membership available	Relevance : Kubernetes configuration benchmark. Notes & POIs : Useful for cluster hardening & exposure scoring.
7	kube-bench Link(s) : github.com/aquasecurity/kube-bench Access / Cost : Free / open-source public GitHub repo	Relevance : Kubernetes CIS benchmark scanner. Notes & POIs : Useful for automated cluster benchmark checks.
8	kube-hunter Link(s) : github.com/aquasecurity/kube-hunter Access / Cost : Free / open-source public GitHub repo	Relevance : Kubernetes penetration testing tool. Notes & POIs : Use only in authorized environments.

18.3 Software assurance, secure development, acquisition & NIST publication libraries

Sl. #	Source Title	Notes
1	CISA Software Acquisition Guide Link(s) : cisa.gov/resources-tools/resources/software-acquisition-guide-government-enterprise-consumers-software-assurance-cyber-supply-chain Access / Cost : Free public; CISA pages may bot-block automated fetchers	Relevance : Software assurance & cyber supply-chain acquisition guidance for enterprise/government consumers. Notes & POIs : Not a vulnerability feed, but useful for procurement, assurance, & supplier-risk context.
2	NIST Secure Software Development Framework - SSDF Link(s) : csrc.nist.gov/projects/ssdf Access / Cost : Free public	Relevance : Secure development practice framework for reducing software vulnerabilities. Notes & POIs : Useful for SDLC controls, attestation, & vulnerability-prevention context.
3	NIST FIPS publications Link(s) : csrc.nist.gov/publications/fips Access / Cost : Free public	Relevance : Federal Information Processing Standards. Notes & POIs : Compliance/standards reference, not vuln feed.
4	NIST Special Publications root Link(s) : csrc.nist.gov/publications/sp Access / Cost : Free public	Relevance : NIST Special Publication library. Notes & POIs : Useful for standards research & compliance mapping.
5	NIST SP 800 series Link(s) : csrc.nist.gov/publications/sp800 Access / Cost : Free public	Relevance : Computer/security guidance series. Notes & POIs : High-value for security-control, risk, identity, cryptography, & vulnerability-management context.
6	NIST SP 1800 series Link(s) : csrc.nist.gov/publications/sp1800 Access / Cost : Free public	Relevance : NIST Cybersecurity Practice Guides. Notes & POIs : Practical implementation patterns & reference architectures.
7	NIST SP 500 series Link(s) : csrc.nist.gov/publications/sp500 Access / Cost : Free public	Relevance : Information technology publications. Notes & POIs : Useful for supporting standards & technical guidance.
8	NIST AI publication search Link(s) : csrc.nist.gov/publications/search?sortBy-lg=relevance&viewMode-lg=brief&ipp-lg=50&status-lg=Final%2CDraft&series-lg=AI Access / Cost : Free public filtered search	Relevance : NIST AI-series publication discovery. Notes & POIs : Filtered search URL; cite individual publications separately when used for evidence.
9	LangGuard SCOPE MCP Link(s) : scope-mcp.langguard.ai Access / Cost : Public web tool/service; terms may apply	Relevance : AI/agent compliance & pre-flight risk evaluation for tool use. Notes & POIs : Useful for AI/agent security governance, not vulnerability source ingestion.
10	FIRST 2026 papers Link(s) : www.first.org/resources/papers/2026	Relevance : FIRST papers & security response knowledge base.

Sl. #	Source Title	Notes
	Access / Cost : Free public	Notes & POIs : Research/training context, not canonical vulnerability data.
11	FIRST VulnCon 2026 program Link(s) : first.org/conference/vulncon26/program Access / Cost : Free public conference page	Relevance : Vulnerability management & disclosure conference content. Notes & POIs : Useful for user stories, emerging practices, & CVE/PSIRT ecosystem context.

[Back to Index](#)

19. Minimal source set for production use

Sl. #	Source Title	
1	CVE List v5 Link(s) : github.com/CVEProject/cvelistV5 Access / Cost : Free public GitHub repo	Relevance : Canonical C Notes & POIs : Start her
2	CVE schema Link(s) : github.com/CVEProject/cve-schema Access / Cost : Free public GitHub repo	Relevance : CVE schem Notes & POIs : Requirec
3	NVD CVE API Link(s) : nvd.nist.gov/developers/vulnerabilities Access / Cost : Free public; optional free API key for higher rate limits	Relevance : CVSS/CPE/ Notes & POIs : Core pro
4	NVD CPE API Link(s) : nvd.nist.gov/developers/products Access / Cost : Free public; optional free API key for higher rate limits	Relevance : Product/pla Notes & POIs : Combin
5	OSV full database Link(s) : google.github.io/osv.dev/data/#full-database-download Access / Cost : Free public	Relevance : OSS packag Notes & POIs : Local mi
6	OSV schema Link(s) : osv.github.io/osv-schema Access / Cost : Free public / open-source	Relevance : OSS vulner Notes & POIs : Needed
7	GitHub Advisory Database repo Link(s) : github.com/github/advisory-database Access / Cost : Free / open-source public GitHub repo	Relevance : Raw GitHub Notes & POIs : Preserve
8	CISA KEV JSON Link(s) : www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json Access / Cost : Free public feed	Relevance : Known expl Notes & POIs : High-pri

Sl. #	Source Title	
9	CISA Vulnrichment Link(s) : github.com/cisagov/vulnrichment Access / Cost : Free public GitHub repo	Relevance : CISA ADP & Notes & POIs : Coverag
10	FIRST EPSS Link(s) : www.first.org/epss Access / Cost : Free public data/API	Relevance : Exploit likeli Notes & POIs : Store sc
11	CWE downloads	cwe.mitre.org/data/dow
12	CAPEC downloads	capec.mitre.org/data/dc
13	ATT&CK STIX data	github.com/mitre-attack
14	MITRE ATLAS	atlas.mitre.org
15	CycloneDX	cyclonedx.org/specifica
16	SPDX	spdx.dev/specifications
17	PURL	github.com/package-ur
18	CSAF	docs.oasis-open.org/cs
19	OpenVEX	github.com/openvex/sp
20	Distro feeds	access.redhat.com/seci tracker.debian.org , ubun
21	Exploit signal feeds	docs.greynoise.io , github.com

[Back to Index](#)

20. Final structure for all vulnerability management sources & exposure listings

Sl. #	Source Title
1	Canonical vulnerability records Link(s) : github.com/CVEProject/cvelistV5 , github.com/cisagov/vulnrichment , nvd.nist.gov , www.cve.org Access / Cost : Free public / open-source; NVD optional API key
2	Package & ecosystem advisories Link(s) : github.com/advisories , github.com/github/advisory-database , osv.dev Access / Cost : Free public / open-source
3	Vendor & distro affectedness

Sl. #	Source Title
	Link(s) : access.redhat.com/security/data, secdb.alpinelinux.org, security-tracker.debian.org, ubuntu.com/security/oval, www.suse.com/support/security/csaf Access / Cost : Mostly free public; some vendor support entitlements may apply
4	Exploitability & prioritization Link(s) : github.com/rapid7/metasploit-framework, viz.greynoise.io, www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json, www.exploit-db.com, www.first.org/epss Access / Cost : Mixed: free public, open-source, free tiers / paid plans
5	Weakness & adversary mapping Link(s) : attack.mitre.org/matrices/enterprise, atlas.mitre.org, capec.mitre.org, cwe.mitre.org Access / Cost : Free public
6	AI-specific vulnerability context Link(s) : atlas.mitre.org, owasp.org/www-project-machine-learning-security-top-10, owasp.org/www-project-10-for-large-language-model-applications, www.nist.gov/itl/ai-risk-management-framework Access / Cost : Free public / open community
7	SBOM & identity Link(s) : cyclonedx.org/specification/overview, github.com/package-url/purl-spec, nvd.nist.gov/products/cpe, spdx.dev/specifications Access / Cost : Free public / open standards
8	Exposure telemetry Link(s) : leakix.net, search.censys.io, viz.greynoise.io, www.shadowserver.org, www.shodan.io Access / Cost : Mixed: free public, free tiers, paid plans, registration-based access

Sl. #	Source Title
9	Malicious package & supply-chain compromise Link(s) : github.com/advisories?query=type%3Amalware, github.com/ossf/malicious-packages, github.com/ossf/package-analysis, security.snyk.io, socket.dev/blog, sonatype.com/resources/vulnerability-database Access / Cost : Mixed: free public, open-source, free tiers / commercial products
10	Detection engineering Link(s) : codeql.github.com, github.com/projectdiscovery/nuclei, google.github.io/oss-fuzz, joern.io, samate.nist.gov/SARD, semgrep.dev Access / Cost : Mixed: free/open-source, free public datasets, commercial tiers for some products
11	Threat intelligence Link(s) : blog.google/threat-analysis-group, blog.talosintelligence.com, cloud.google.com/blog/topics/threat-intelligence, unit42.paloaltonetworks.com, www.microsoft.com/en-us/security/blog/topic/threat-intelligence, www.rapid7.com/blog/tag/vulnerability-management, www.ransomware.live Access / Cost : Mostly free public blogs/research; commercial threat intel products separate
12	Compliance & configuration impact Link(s) : github.com/ComplianceAsCode/content, ncp.nist.gov, public.cyber.mil/stigs, www.cisecurity.org/cis-benchmarks, www.open-scap.org Access / Cost : Mostly free public / open-source; CIS benchmarks may require free registration & commercial to exist

[Back to Index](#)

License

Copyright © 2025 Keerthana Purushotham keep.consult@proton.me. Licensed under the GNU AGPL v3. See LICENSE for details. [see license](#)

Note:

Some vendor/security pages change URLs over time, so treat this as a high-coverage baseline rather than a mathematically exhaustive list of every possible vulnerability source.